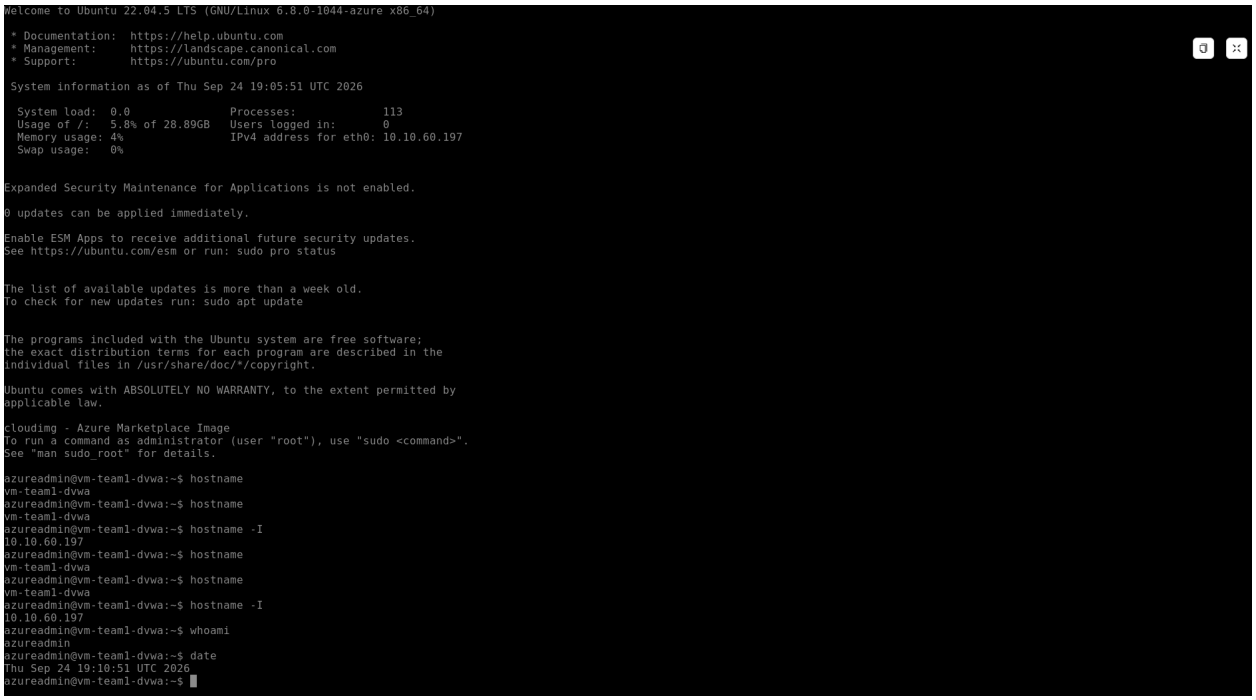
Ironbridge National Bank - Full Documentation

This documents the full timeline and procedures of building and hardening the environment, maintaining stand up monitoring, keeping compliance with PCI DSS, and detecting and responding to a live security incident for Ironbridge National Bank.

Part A: Build and Harden the Environment

Part A1. Connect to Your Environment

Connecting to Linux Web App/ Jumpbox (vm-team1-dvwa of the rg-cybersec-capstone-team4 resource group)



Connection From: azureadmin
Private IP: 10.10.60.197
Date/Time: Thu Sep 24 19:10:51 UTC 2026

Connecting to Domain Controller (vm-team4-dc)




```
PS C:\Users\azureadmin> ipconfig

Windows IP Configuration


Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . : m5ctnbzdv54urhmglwbtqqyaha.cx.internal.cloudapp.net
   Link-local IPv6 Address . . . . . : fe80::555e:807d:9182:c106%6
   IPv4 Address. . . . . . . . . . . : 10.10.60.196
   Subnet Mask . . . . . . . . . . . : 255.255.255.192
   Default Gateway . . . . . . . . . : 10.10.60.193
```

(IP 10.10.60.196)

```
PS C:\Users\azureadmin> "$(Get-Date -Format 'yyyy-MM-dd HH:mm:ss') - $(whoami) connected to $(hostname)"
2026-09-25 17:07:25 - vm-team4-dc\azureadmin connected to vm-team4-dc
```

(Connection from azureadmin to vm-team4-dc on 09-25-2026 at 17:07:25 UTC)

Part A2. Establish and Record Baseline

Establishing baseline for Linux Web App / Jumpbox:

```
azureadmin@vm-team1-dvwa:~$ mkdir -p ~/baseline
azureadmin@vm-team1-dvwa:~$ cd ~/baseline
azureadmin@vm-team1-dvwa:~/baseline$ date
Thu Sep 24 19:27:39 UTC 2026
azureadmin@vm-team1-dvwa:~/baseline$
```

Create /baseline directory

Nmap Scan the Windows DC from the Linux jump box:

```
azureadmin@vm-team1-dvwa:~/baseline$ sudo nmap -sV 10.10.60.196 -oN vm-team4-dc_2026-09-24_nmap.txt
Starting Nmap 7.80 ( https://nmap.org ) at 2026-09-25 17:57 UTC
Nmap scan report for vm-team4-dc.internal.cloudapp.net (10.10.60.196)
Host is up (0.00087s latency).
Not shown: 999 filtered ports
PORT     STATE SERVICE       VERSION
3389/tcp open  ms-wbt-server Microsoft Terminal Services
MAC Address: 12:34:56:78:9A:BC (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.83 seconds
```

Nmap service/version scan of Windows DC
Saved to /baseline/vm-team4-dc_2026-09-24_nmap.txt

Baseline Linux Running Services:

```
azureadmin@vm-team1-dvwa:~/baseline$ systemctl --type=service --state=running
  UNIT                        LOAD   ACTIVE SUB     DESCRIPTION
  chrony.service              loaded active running chrony, an NTP client/server
  cron.service                loaded active running Regular background program processing daemon
  dbus.service                loaded active running D-Bus System Message Bus
  getty@tty1.service          loaded active running Getty on tty1
  hv-kvp-daemon.service       loaded active running Hyper-V KVP Protocol Daemon
  irqbalance.service          loaded active running irqbalance daemon
  multipathd.service          loaded active running Device-Mapper Multipath Device Controller
  networkd-dispatcher.service loaded active running Dispatcher daemon for systemd-networkd
  packagekit.service          loaded active running PackageKit Daemon
  polkit.service              loaded active running Authorization Manager
  rsyslog.service             loaded active running System Logging Service
  serial-getty@ttyS0.service  loaded active running Serial Getty on ttyS0
  snapd.service               loaded active running Snap Daemon
  ssh.service                 loaded active running OpenBSD Secure Shell server
  systemd-journald.service    loaded active running Journal Service
  systemd-logind.service      loaded active running User Login Management
  systemd-networkd.service    loaded active running Network Configuration
  systemd-resolved.service    loaded active running Network Name Resolution
  systemd-udevd.service       loaded active running Rule-based Manager for Device Events and Files
  unattended-upgrades.service loaded active running Unattended Upgrades Shutdown
  user@1000.service           loaded active running User Manager for UID 1000
  walinuxagent.service        loaded active running Azure Linux Agent

LOAD   = Reflects whether the unit definition was properly loaded.
ACTIVE = The high-level unit activation state, i.e. generalization of SUB.
SUB    = The low-level unit activation state, values depend on unit type.
22 loaded units listed.
azureadmin@vm-team1-dvwa:~/baseline$ systemctl --type=service --state=running > ~/baseline/vm-team4-dvwa_2026-09-24_services.txt
azureadmin@vm-team1-dvwa:~/baseline$
```

Saved to /baseline/vm-team4-dvwa_2026-09-24_services.txt

Baseline Linux Listening Ports:

```
azureadmin@vm-team1-dvwa:~/baseline$ sudo ss -tulpn
Netid          State           Recv-Q          Send-Q                    Local Address:Port                  Peer Address:Port         Process
udp            UNCONN          0               0                      127.0.0.53%lo:53                       0.0.0.0:*             users:(("systemd-resolve",pid=513,fd=13))
udp            UNCONN          0               0                  10.10.60.197%eth0:68                       0.0.0.0:*             users:(("systemd-network",pid=511,fd=18))
udp            UNCONN          0               0                       127.0.0.1:323                         0.0.0.0:*             users:(("chronyd",pid=702,fd=6))
udp            UNCONN          0               0                           [::1]:323                          [::]:*               users:(("chronyd",pid=702,fd=7))
tcp            LISTEN          0               128                       0.0.0.0:22                         0.0.0.0:*             users:(("sshd",pid=729,fd=3))
tcp            LISTEN          0               4096                   127.0.0.53%lo:53                       0.0.0.0:*             users:(("systemd-resolve",pid=513,fd=14))
tcp            LISTEN          0               128                          [::]:22                            [::]:*               users:(("sshd",pid=729,fd=4))
azureadmin@vm-team1-dvwa:~/baseline$ sudo ss -tulpn > ~/baseline/vm-team4-dvwa_2026-09-24_ports.txt
```

Saved to /baseline/vm-team4-dvwa_2026-09-24_ports.txt

Linux User Accounts:

```
azureadmin@vm-team1-dvwa:~/baseline$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:112:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:113::/run/uuidd:/usr/sbin/nologin
tcpdump:x:108:114::/nonexistent:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
pollinate:x:110:1::/var/cache/pollinate:/bin/false
landscape:x:111:116::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:117:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
_chrony:x:113:122:Chrony daemon,,,:/var/lib/chrony:/usr/sbin/nologin
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
azureadmin:x:1000:1000:Ubuntu:/home/azureadmin:/bin/bash
azureadmin@vm-team1-dvwa:~/baseline$ cat /etc/passwd > ~/baseline/vm-team4-dvwa_2026-09-24_users.txt
azureadmin@vm-team1-dvwa:~/baseline$
```

Saved to /baseline/vm-team4-dvwa_2026-09-24_users.txt

Linux Accounts with Login Shell:

```
azureadmin@vm-team1-dvwa:~/baseline$ awk -F: '$7 !~ /(nologin|false)$/ {print $1, $7}' /etc/passwd
root /bin/bash
sync /bin/sync
azureadmin /bin/bash
azureadmin@vm-team1-dvwa:~/baseline$ awk -F: '$7 !~ /(nologin|false)$/ {print $1, $7}' /etc/passwd > ~/baseline/vm-team4-dvwa_2026-09-24_login_accounts.txt
```

Saved to /baseline/vm-team4-dvwa_2026-09-24_login_accounts.txt

Linux Sudo Configuration:

```
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1044-azure x86_64)

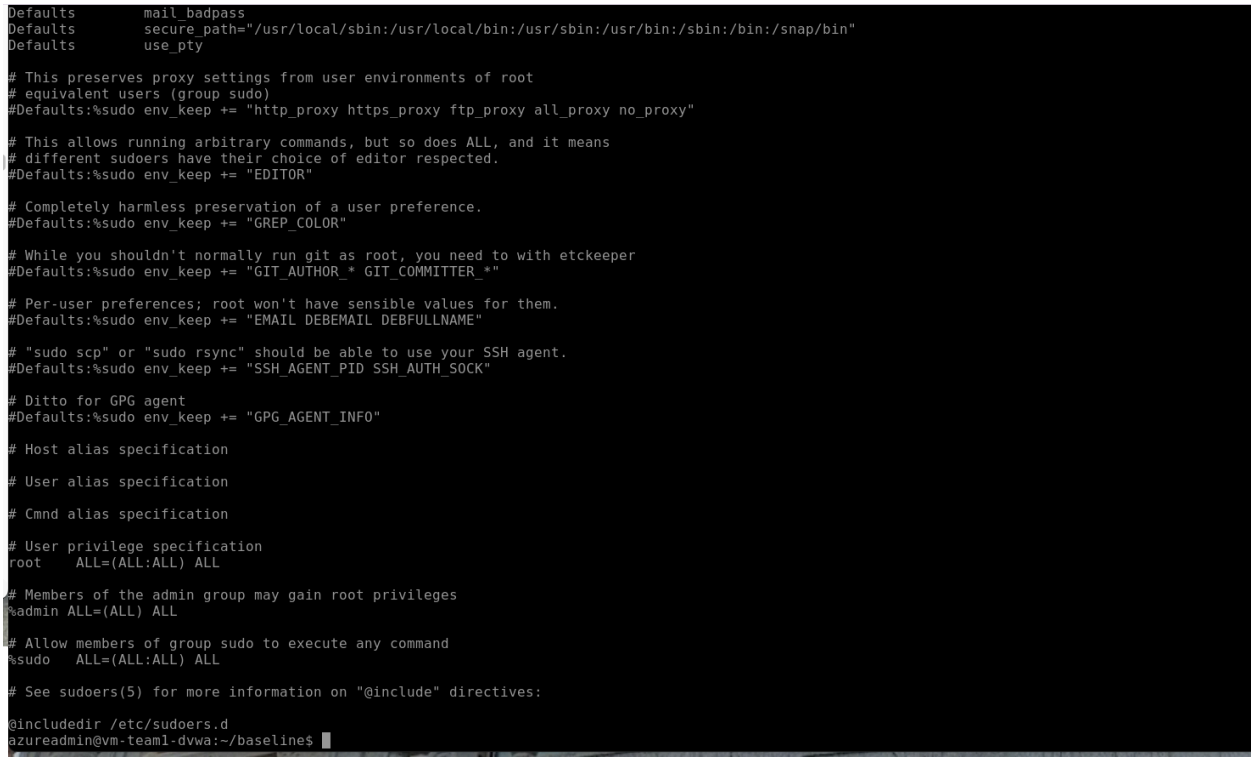
 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

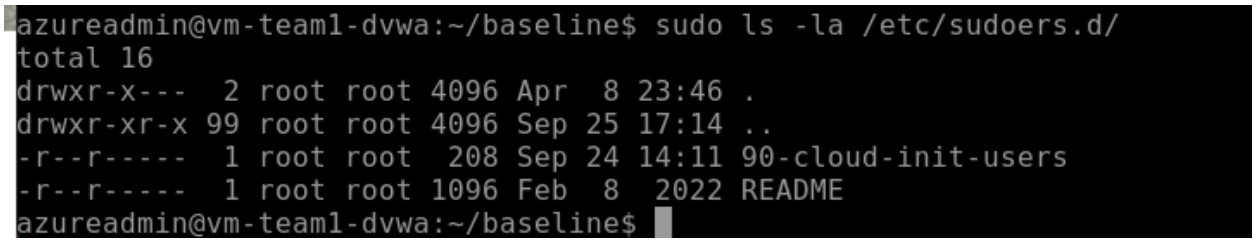
 System information as of Fri Sep 25 17:13:39 UTC 2026

  System load:  0.0               Processes:             114
  Usage of /:   7.1% of 28.89GB   Users logged in:       0
  Memory usage: 4%                IPv4 address for eth0: 10.10.60.197
  Swap usage:   0%


Expanded Security Maintenance for Applications is not enabled.

Defaults        env_reset
Defaults        mail_badpass
Defaults        secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"
Defaults        use_pty
```







Saved to /baseline/vm-team4-dvwa_2026-09-24_sudoers.txt
Saved to ~/baseline/vm-team4-dvwa_2026-09-24_sudoers_d.txt

Linux Installed Software:

```
azureadmin@vm-team1-dvwa:~/baseline$ dpkg -l
Desired=Unknown/Install/Remove/Purge/Hold
| Status=Not/Inst/Conf-files/Unpacked/halF-conf/Half-inst/trig-aWait/Trig-pend
|/ Err?=(none)/Reinst-required (Status,Err: uppercase=bad)
||/ Name                                 Version                                 Architecture Description
+++-====================================-=======================================-============-===============================================================================
ii  adduser                              3.118ubuntu5                            all          add and remove users and groups
ii  apparmor                             3.0.4-2ubuntu2.5                        amd64        user-space parser utility for AppArmor
ii  apport                               2.20.11-0ubuntu82.10                    all          automatically generate crash reports for debugging
ii  apport-symptoms                      0.24                                    all          symptom scripts for apport
ii  apt                                  2.4.14                                  amd64        commandline package manager
ii  apt-utils                            2.4.14                                  amd64        package management related utility programs
ii  azure-vm-utils                       0.6.0-4~ubuntu0.22.04.1                 amd64        Core utilities and configuration for Linux VMs on Azure
ii  base-files                           12ubuntu4.7                             amd64        Debian base system miscellaneous files
ii  base-passwd                          3.5.52build1                            amd64        Debian base system master password and group files
ii  bash                                 5.1-6ubuntu1.1                          amd64        GNU Bourne Again SHell
ii  bash-completion                      1:2.11-5ubuntu1                         all          programmable completion for the bash shell
ii  bc                                   1.07.1-3build1                          amd64        GNU bc arbitrary precision calculator language
ii  bcache-tools                         1.0.8-4ubuntu3                          amd64        bcache userspace tools
ii  bind9-dnsutils                       1:9.18.39-0ubuntu0.22.04.2              amd64        Clients provided with BIND 9
ii  bind9-host                           1:9.18.39-0ubuntu0.22.04.2              amd64        DNS Lookup Utility
ii  bind9-libs:amd64                     1:9.18.39-0ubuntu0.22.04.2              amd64        Shared Libraries used by BIND 9
ii  binutils                             2.38-4ubuntu2.12                        amd64        GNU assembler, linker and binary utilities
ii  binutils-common:amd64                2.38-4ubuntu2.12                        amd64        Common files for the GNU assembler, linker and binary utilities
ii  binutils-x86-64-linux-gnu            2.38-4ubuntu2.12                        amd64        GNU binary utilities, for x86-64-linux-gnu target
ii  bolt                                 0.9.2-1                                 amd64        system daemon to manage thunderbolt 3 devices
ii  bsdextrautils                        2.37.2-4ubuntu3.4                       amd64        extra utilities from 4.4BSD-Lite
ii  bsdutils                             1:2.37.2-4ubuntu3.4                     amd64        basic utilities from 4.4BSD-Lite
ii  btrfs-progs                          5.16.2-1                                amd64        Checksumming Copy on Write Filesystem utilities
ii  busybox-initramfs                    1:1.30.1-7ubuntu3.1                     amd64        Standalone shell setup for initramfs
ii  busybox-static                       1:1.30.1-7ubuntu3.1                     amd64        Standalone rescue shell with tons of builtin utilities
ii  byobu                                5.133-1                                 all          text window manager, shell multiplexer, integrated DevOps environment
ii  ca-certificates                      20240203~22.04.1                        all          Common CA certificates
ii  chrony                               4.2-2ubuntu2                            amd64        Versatile implementation of the Network Time Protocol
ii  cifs-utils                           2:6.14-1ubuntu0.3                       amd64        Common Internet File System utilities
ii  cloud-guest-utils                    0.32-22-g45fe84a5-0ubuntu1              all          cloud guest utilities
ii  cloud-init                           25.3-0ubuntu1~22.04.1                   all          initialization and customization tool for cloud instances
ii  cloud-initramfs-copymods             0.47ubuntu1                             all          copy initramfs modules into root filesystem for later use
ii  cloud-initramfs-dyn-netconf          0.47ubuntu1                             all          write a network interface file in /run for BOOTIF
ii  command-not-found                    22.04.0                                 all          Suggest installation of packages in interactive bash sessions
ii  console-setup                        1.205ubuntu3                            all          console font and keymap setup program
```

```
azureadmin@vm-team1-dvwa:~/baseline$ dpkg -l > ~/baseline/vm-team4-dvwa_2026-09-24_installed_software.txt
azureadmin@vm-team1-dvwa:~/baseline$
```

Saved to ~/baseline/vm-team4-dvwa_2026-09-24_installed_software.txt

Establishing Baseline for Windows Host:

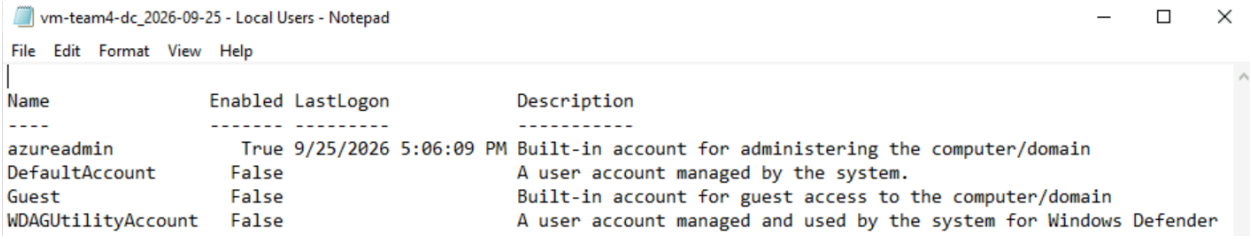
Port Scan:



Port	State	Service	Version	Purpose
135 / tcp	Open	msrpc	Microsoft Windows RPC	RPC endpoint mapper, used by Windows remote management and many services
137 / tcp	Filtered	netbios-ns		NetBIOS name service, blocked by the firewall
139 / tcp	Open	netbios-ssn	Microsoft Windows netbios-ssn	Older NetBIOS file and printer sharing

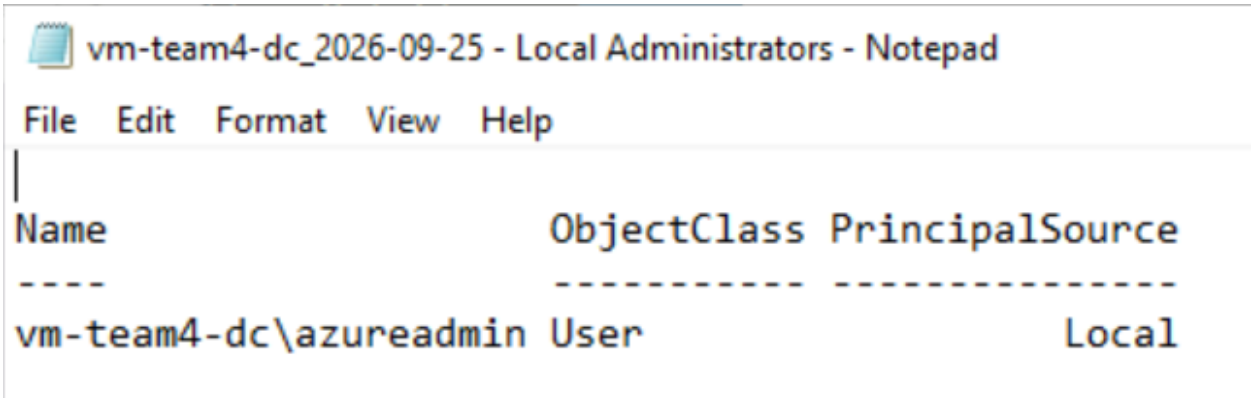
445 / tcp	Open	microsoft-ds		SMB file sharing
3389 / tcp	Open	ms-wbt-server	Microsoft Terminal Services	RDP
5985 / tcp	Open	http	Microsoft HTTPAPI httpd 2.0	WinRM (PowerShell remoting over HTTP)
47001 / tcp	Open	http	Microsoft HTTPAPI httpd 2.0	WinRM internal listener
49664 - 49667 / tcp	Open	unknown		Dynamic RPC ports used by Windows services
49669 - 49671 / tcp	Open	unknown		Dynamic RPC ports used by Windows services

Local user accounts:



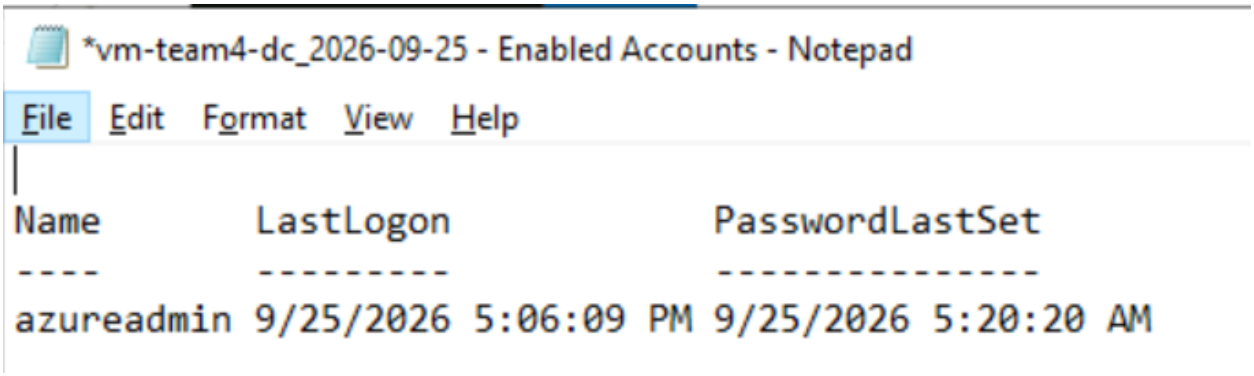
Name	Enabled	Last Logon	Description
azureadmin	True	9/25/2026 5:06:09 PM UTC	Built-in account for administering the computer/domain
DefaultAccount	False		A user account managed by the system
Guest	False		Built-in account for guest access to the computer/domain
WDAGUtilityAccount	False		A user account managed and used by the system for Windows Defender

Local administrators group members:



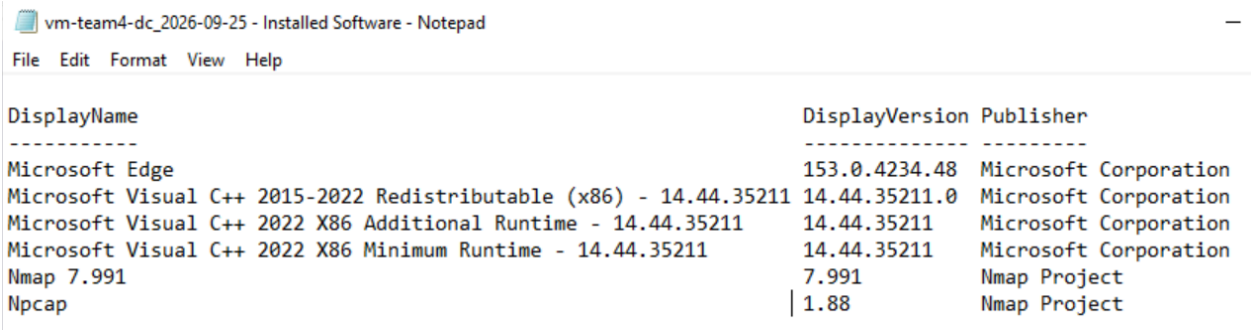
Name	ObjectClass	PrincipalSource
Vm-team4-dc\azureadmin	User	Local

Enabled accounts:



Name	LastLogon	PasswordLastSet
azureadmin	9/25/2026 5:06:09 PM UTC	9/25/2026 5:20:20 AM UTC

Installed software:



Display Name	Version	Publisher
Microsoft Edge	153.0.4234.48	Microsoft Corporation
Microsoft Visual C++ 2015-2022 Redistributable (x86) - 14.44.35211	14.44.35211.0	Microsoft Corporation
Microsoft Visual C++ 2022 X86 Additional Runtime - 14.44.35211	14.44.35211	Microsoft Corporation
Microsoft Visual C++ 2022 X86 Minimum Runtime - 14.44.35211	14.44.35211	Microsoft Corporation
Nmap 7.991	7.991	Nmap Project
Npcap	1.88	Nmap Project

Installed Features

```
Name                    DisplayName                 InstallState
----                    -----------                 ------------
FileAndStorage-Services File and Storage Services       Installed
Storage-Services        Storage Services                Installed
NET-Framework-45-Features .NET Framework 4.8 Features   Installed
NET-Framework-45-Core   .NET Framework 4.8              Installed
NET-WCF-Services45      WCF Services                    Installed
NET-WCF-TCP-PortSharing45 TCP Port Sharing              Installed
AzureArcSetup           Azure Arc Setup                 Installed
BitLocker               BitLocker Drive Encryption      Installed
EnhancedStorage         Enhanced Storage                Installed
Windows-Defender        Microsoft Defender Antivirus    Installed
System-DataArchiver     System Data Archiver            Installed
PowerShellRoot          Windows PowerShell              Installed
PowerShell              Windows PowerShell 5.1          Installed
WoW64-Support           WoW64 Support                   Installed
XPS-Viewer              XPS Viewer                      Installed
```

Name	Display Name	Function
FileAndStorage-Services	File and Storage Services	Base role for managing files, shares, and disks. It's part of the OS and can't be removed
Storage-Services	Storage Services	Core storage management functions that the role above relies on
NET-Framework-45-Features	.NET Framework 4.8 Features	Parent feature that groups the .NET 4.8 components

NET-Framework-45-Core	.NET Framework 4.8	Runtime that PowerShell, AD tools, and many Windows programs need to run
NET-WCF-Services45	WCF Services	Windows Communication Foundation, which lets .NET applications talk to each other over a network
NET-WCF-TCP-PortSharing45	TCP Port Sharing	Lets multiple WCF applications share a single TCP port
AzureArcSetup	Azure Arc Setup	Wizard for connecting the server to Azure Arc, Microsoft's hybrid management service
BitLocker	BitLocker Drive Encryption	Encrypts disk volumes to protect data at rest
EnhancedStorage	Enhanced Storage	Supports hardware-encrypted drives with built-in security features
Windows-Defender	Microsoft Defender Antivirus	Built-in antivirus and malware protection
System-DataArchiver	System Data Archiver	Collects system diagnostic data for Windows. It's an OS component
PowerShellRoot	Windows PowerShell	Parent feature that groups the PowerShell components
PowerShell	Windows PowerShell 5.1	The command shell and scripting environment you use to manage the server
WoW64-Support	WoW64 Support	Allows 32-bit programs to run on the 64-bit OS
XPS-Viewer	XPS Viewer	Opens XPS documents, Microsoft's alternative to PDF

Part A3. Harden the Linux Host (Web App and Jump Box)

Update and patch fully with the system package manager, then reboot if a kernel update applied

```
azureadmin@vm-team1-dvwa:~$ mkdir -p ~/A3_evidence
azureadmin@vm-team1-dvwa:~$ ls -la
total 44
drwxr-x--- 6 azureadmin azureadmin 4096 Sep 30 19:04 .
drwxr-xr-x 3 root       root       4096 Sep 24 14:11 ..
-rw------- 1 azureadmin azureadmin 1397 Sep 25 18:54 .bash_history
-rw-r--r-- 1 azureadmin azureadmin  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 azureadmin azureadmin 3771 Jan  6  2022 .bashrc
drwx------ 2 azureadmin azureadmin 4096 Sep 24 19:05 .cache
-rw------- 1 azureadmin azureadmin   20 Sep 25 17:47 .lesshst
-rw-r--r-- 1 azureadmin azureadmin  807 Jan  6  2022 .profile
drwx------ 2 azureadmin azureadmin 4096 Sep 24 14:11 .ssh
-rw-r--r-- 1 azureadmin azureadmin    0 Sep 24 19:34 .sudo_as_admin_successful
drwxrwxr-x 2 azureadmin azureadmin 4096 Sep 30 19:04 A3_evidence
drwxrwxr-x 2 azureadmin azureadmin 4096 Sep 25 17:57 baseline
azureadmin@vm-team1-dvwa:~$ apt list --upgradable
Listing... Done
azureadmin@vm-team1-dvwa:~$
```

‘Mkdir -p ~/A3_evidence’ to create directory containing hardening evidence

```
azureadmin@vm-team1-dvwa:~$ if [ -f /var/run/reboot-required ]; then
>     cat /var/run/reboot-required
> else
>     echo "No reboot currently required"
> fi
*** System restart required ***
azureadmin@vm-team1-dvwa:~$ sudo reboot
```

Sudo apt upgrade, install, and then reboot

```
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1068-azure x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Wed Sep 30 19:06:46 UTC 2026

  System load:  0.89              Processes:             148
  Usage of /:   9.0% of 28.89GB   Users logged in:       0
  Memory usage: 4%                IPv4 address for eth0: 10.10.60.197
  Swap usage:   0%

 * Canonical Workshop gives developers fast, composable, reproducible, and
   secure developer environments that are perfect for agentic workflows.

   https://ubuntu.com/workshop

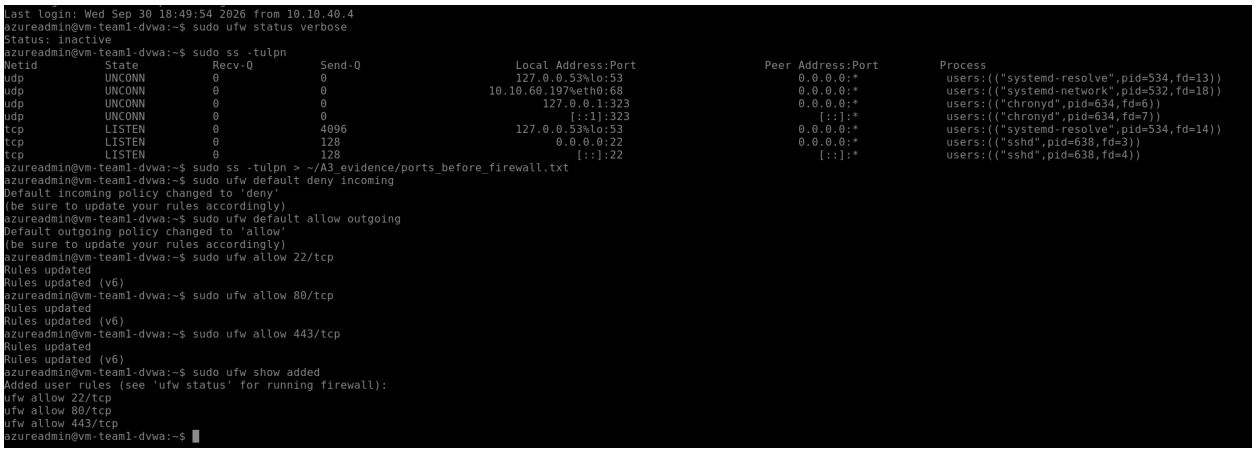
Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

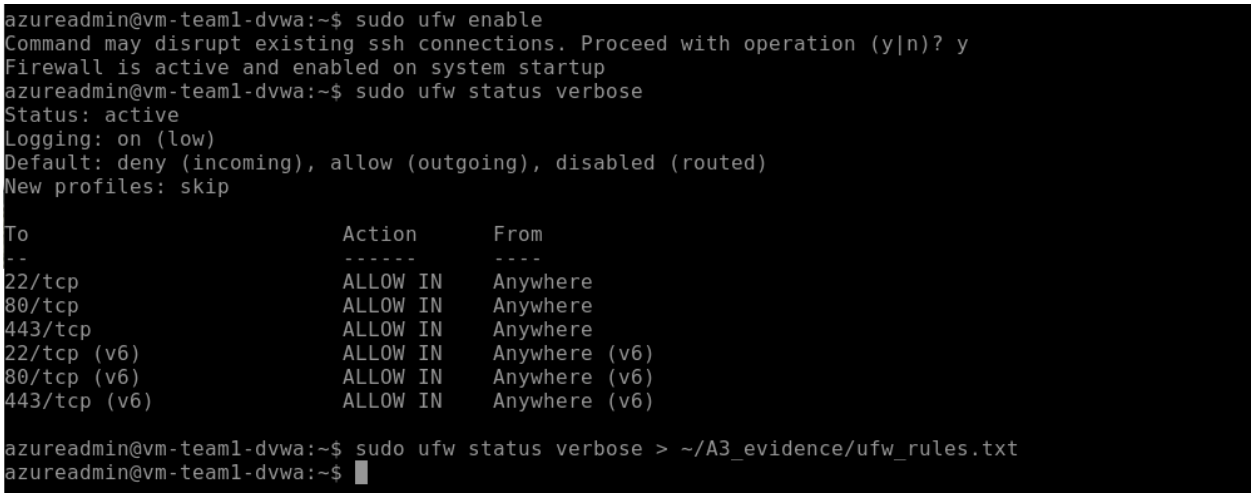

cloudimg - Azure Marketplace Image
Last login: Wed Sep 30 18:49:54 2026 from 10.10.40.4
azureadmin@vm-team1-dvwa:~$
```

Configure the Linux firewall



‘sudo ss -tulpn’ sees current listening ports, saved to ~/A3_evidence/ports_before_firewall.txt
‘sudo ufw default deny incoming’ and ‘sudo ufw default allow outgoing’ to set default firewall behavior

‘sudo ufw allow 22/tcp’ allows SSH
‘sudo ufw allow 80/tcp’ allows HTTP
‘sudo ufw allow 443/tcp’ allows HTTPS



‘sudo ufw default deny incoming’ and ‘sudo ufw default allow outgoing’ to set default firewall behavior

‘sudo ufw enable’ enables firewall
‘sudo ufw status verbose’ shows active firewall status with allowed ports saved to ~/A3_evidence/ufw_rules.txt

Harden SSH: Disable Root Login

```
Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile     .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody


azureadmin@vm-team1-dvwa:~$ sudo sshd -t
azureadmin@vm-team1-dvwa:~$ sudo systemctl restart ssh
azureadmin@vm-team1-dvwa:~$ sudo sshd -T | grep -E 'permitrootlogin|passwordauthentication|pubkeyauthentication'
permitrootlogin no
pubkeyauthentication yes
passwordauthentication yes
azureadmin@vm-team1-dvwa:~$
```

‘sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.before_A3’ backup created
‘sudo nano /etc/ssh/sshd_config’, permitrootlogin changed to no

```
azureadmin@vm-team1-dvwa:~$ sudo sshd -T | grep -E 'permitrootlogin|passwordauthentication|pubkeyauthentication' > ~/A3_evidence/ssh_root_disabled.txt
```

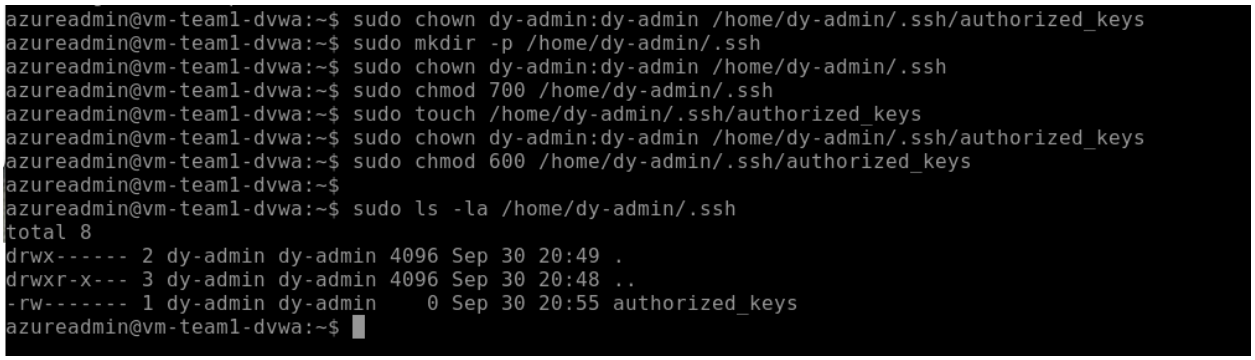
Create individual named accounts

```
azureadmin@vm-team1-dvwa:~$ sudo adduser jm-admin
Adding user `jm-admin' ...
Adding new group `jm-admin' (1001) ...
Adding new user `jm-admin' (1001) with group `jm-admin' ...
Creating home directory `/home/jm-admin' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for jm-admin
Enter the new value, or press ENTER for the default
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n] y
azureadmin@vm-team1-dvwa:~$ sudo adduser dy-admin
Adding user `dy-admin' ...
Adding new group `dy-admin' (1002) ...
Adding new user `dy-admin' (1002) with group `dy-admin' ...
Creating home directory `/home/dy-admin' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for dy-admin
Enter the new value, or press ENTER for the default
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n] y
azureadmin@vm-team1-dvwa:~$ sudo usermod -aG sudo jm-admin
azureadmin@vm-team1-dvwa:~$ id jm-admin
uid=1001(jm-admin) gid=1001(jm-admin) groups=1001(jm-admin),27(sudo)
azureadmin@vm-team1-dvwa:~$ id dy-admin
uid=1002(dy-admin) gid=1002(dy-admin) groups=1002(dy-admin)
azureadmin@vm-team1-dvwa:~$ sudo usermod -aG sudo dy-admin
azureadmin@vm-team1-dvwa:~$ id dy-admin
uid=1002(dy-admin) gid=1002(dy-admin) groups=1002(dy-admin),27(sudo)
azureadmin@vm-team1-dvwa:~$ getent group sudo
sudo:x:27:azureadmin,jm-admin,dy-admin
azureadmin@vm-team1-dvwa:~$ getent group sudo > ~/A3_evidence/sudo_group_after.txt
azureadmin@vm-team1-dvwa:~$
```

Jm-admin and dy-admin accounts created
User: jm-admin Password: JM$password12345

User: dy-admin Password: DY$password12345

Configure SSH keys for admin accounts and disabling Password login



‘sudo mkdir -p /home/dy-admin/.ssh’ created .ssh directory
Dy-admin ownership and 700(read,write,access) permissions set

‘sudo touch /home/dy-admin/.ssh/authorized_keys’ creates authorized_keys file
Dy-admin ownership and 600(read,write) permissions set



Public key generated copied into authorized_key file
Process repeated for jm-admin respectively

```
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile     .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes
#KerberosGetAFSToken no

# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes
#GSSAPIStrictAcceptorCheck yes
#GSSAPIKeyExchange no


azureadmin@vm-team1-dvwa:~$ sudo nano /etc/ssh/sshd_config
```

‘sudo nano /etc/ssh/sshd_config’, PasswordAuthentication set to no
‘sudo nano /etc/ssh/sshd_config.d/50-cloud-init.conf’, PasswordAuthentication set to no

Disable Unused Packages and Services

```
cloudimg - Azure Marketplace Image
Last login: Wed Sep 30 22:08:23 2026 from 10.10.40.4
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

jm-admin@vm-team1-dvwa:~$ systemctl --type=service --state=running
  UNIT                              LOAD   ACTIVE SUB     DESCRIPTION
  chrony.service                    loaded active running chrony, an NTP client/server
  cron.service                      loaded active running Regular background program processing daemon
  dbus.service                      loaded active running D-Bus System Message Bus
  getty@tty1.service                loaded active running Getty on tty1
  hv-kvp-daemon.service             loaded active running Hyper-V KVP Protocol Daemon
  irqbalance.service                loaded active running irqbalance daemon
  multipathd.service                loaded active running Device-Mapper Multipath Device Controller
  networkd-dispatcher.service loaded active running Dispatcher daemon for systemd-networkd
  rsyslog.service                   loaded active running System Logging Service
  serial-getty@ttyS0.service  loaded active running Serial Getty on ttyS0
  snapd.service                     loaded active running Snap Daemon
  ssh.service                       loaded active running OpenBSD Secure Shell server
  systemd-journald.service          loaded active running Journal Service
  systemd-logind.service            loaded active running User Login Management
  systemd-networkd.service          loaded active running Network Configuration
  systemd-resolved.service          loaded active running Network Name Resolution
  systemd-udevd.service             loaded active running Rule-based Manager for Device Events and Files
  unattended-upgrades.service loaded active running Unattended Upgrades Shutdown
  user@1000.service                 loaded active running User Manager for UID 1000
  user@1001.service                 loaded active running User Manager for UID 1001
  walinuxagent.service              loaded active running Azure Linux Agent

LOAD   = Reflects whether the unit definition was properly loaded.
ACTIVE = The high-level unit activation state, i.e. generalization of SUB.
SUB    = The low-level unit activation state, values depend on unit type.
21 loaded units listed.
jm-admin@vm-team1-dvwa:~$ sudo ss -tulpn
[sudo] password for jm-admin:
Netid          State           Recv-Q          Send-Q                    Local Address:Port                Peer Address:Port         Process
udp            UNCONN          0               0                         127.0.0.53%lo:53                       0.0.0.0:*             users:(("systemd-resolve",pid=534,fd=13))
udp            UNCONN          0               0                 10.10.60.197%eth0:68                   0.0.0.0:*             users:(("systemd-network",pid=532,fd=18))
udp            UNCONN          0               0                       127.0.0.1:323                    0.0.0.0:*             users:(("chronyd",pid=634,fd=6))
udp            UNCONN          0               0                           [::1]:323                       [::]:*             users:(("chronyd",pid=634,fd=7))
tcp            LISTEN          0               4096                    127.0.0.53%lo:53                   0.0.0.0:*             users:(("systemd-resolve",pid=534,fd=14))
tcp            LISTEN          0               128                           0.0.0.0:22                   0.0.0.0:*             users:(("sshd",pid=3383,fd=3))
tcp            LISTEN          0               128                             [::]:22                      [::]:*             users:(("sshd",pid=3383,fd=4))
jm-admin@vm-team1-dvwa:~$
```

```
jm-admin@vm-team1-dvwa:~$ snap list
Name    Version         Rev    Tracking       Publisher   Notes
core20  20260901        2922   latest/stable  canonical✓  base
core22  20260824        2955   latest/stable  canonical✓  base
lxd     5.0.10-24fe763  40911  5.0/stable/…   canonical✓  -
snapd   2.76.3          27738  latest/stable  canonical✓  snapd
jm-admin@vm-team1-dvwa:~$ sudo lxc list
If this is your first time running LXD on this machine, you should also run: lxd init
To start your first container, try: lxc launch ubuntu:22.04
Or for a virtual machine: lxc launch ubuntu:22.04 --vm

+------+-------+------+------+------+-----------+
| NAME | STATE | IPV4 | IPV6 | TYPE | SNAPSHOTS |
+------+-------+------+------+------+-----------+
jm-admin@vm-team1-dvwa:~$ sudo systemctl disable --now snapd.service
Removed /etc/systemd/system/multi-user.target.wants/snapd.service.
Warning: Stopping snapd.service, but it can still be activated by:
  snapd.socket
jm-admin@vm-team1-dvwa:~$ systemctl is-enabled snapd.service
disabled
jm-admin@vm-team1-dvwa:~$ systemctl is-active snapd.service
inactive
jm-admin@vm-team1-dvwa:~$
```

Snapd.service disabled; lxd manager showed no configured or running instances which is proof it is not necessary to be enabled for this VM

```
jm-admin@vm-team1-dvwa:~$ systemctl status open-vm-tools.service --no-pager
○ open-vm-tools.service - Service for virtual machines hosted on VMware
     Loaded: loaded (/lib/systemd/system/open-vm-tools.service; enabled; vendor preset: enabled)
     Active: inactive (dead)
  Condition: start condition failed at Wed 2026-09-30 19:06:41 UTC; 3h 54min ago
       Docs: http://open-vm-tools.sourceforge.net/about.php
jm-admin@vm-team1-dvwa:~$ systemctl status open-vm-tools.service --no-pager
○ open-vm-tools.service - Service for virtual machines hosted on VMware
     Loaded: loaded (/lib/systemd/system/open-vm-tools.service; enabled; vendor preset: enabled)
     Active: inactive (dead)
  Condition: start condition failed at Wed 2026-09-30 19:06:41 UTC; 3h 54min ago
       Docs: http://open-vm-tools.sourceforge.net/about.php
jm-admin@vm-team1-dvwa:~$ systemctl status vgauth.service --no-pager
○ vgauth.service - Authentication service for virtual machines hosted on VMware
     Loaded: loaded (/lib/systemd/system/vgauth.service; enabled; vendor preset: enabled)
     Active: inactive (dead)
  Condition: start condition failed at Wed 2026-09-30 19:06:41 UTC; 3h 55min ago
       Docs: http://github.com/vmware/open-vm-tools
jm-admin@vm-team1-dvwa:~$
```

```
jm-admin@vm-team1-dvwa:~$ systemctl is-enabled open-vm-tools.service vgauth.service | tee ~/A3_evidence/vmware_services_enabled_before.txt
tee: /home/jm-admin/A3_evidence/vmware_services_enabled_before.txt: No such file or directory
enabled
enabled
jm-admin@vm-team1-dvwa:~$ sudo systemctl disable open-vm-tools.service
[sudo] password for jm-admin:
Synchronizing state of open-vm-tools.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable open-vm-tools
Removed /etc/systemd/system/multi-user.target.wants/open-vm-tools.service.
Removed /etc/systemd/system/vmtoolsd.service.
jm-admin@vm-team1-dvwa:~$ sudo systemctl disable open-vm-tools.service
Synchronizing state of open-vm-tools.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable open-vm-tools
jm-admin@vm-team1-dvwa:~$ sudo systemctl disable open-vm-tools.service
Synchronizing state of open-vm-tools.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable open-vm-tools
jm-admin@vm-team1-dvwa:~$ sudo systemctl disable open-vm-tools.service
Synchronizing state of open-vm-tools.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable open-vm-tools
jm-admin@vm-team1-dvwa:~$ sudo systemctl disable vgauth.service
Removed /etc/systemd/system/open-vm-tools.service.requires/vgauth.service.

jm-admin@vm-team1-dvwa:~$ systemctl is-enabled open-vm-tools.service vgauth.service
disabled
disabled
jm-admin@vm-team1-dvwa:~$
```

Open-vm-tool.service and vgauth.service are disabled; They were found enabled but inactive, they are VMware guest utilities, while this host is deployed as an Azure VM; Start conditions were already failing because the applicable VMware environment was not detected which is evidence that these services don't need to be enabled

Set correct ownership and least-privilege permissions on the web root and any file that holds data

```
jm-admin@vm-team1-dvwa:~$ sudo systemctl enable --now apache2
Synchronizing state of apache2.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable apache2
jm-admin@vm-team1-dvwa:~$ systemctl status apache2 --no-pager
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
     Active: active (running) since Thu 2026-10-01 17:58:42 UTC; 31s ago
       Docs: https://httpd.apache.org/docs/2.4/
   Main PID: 9406 (apache2)
      Tasks: 55 (limit: 9500)
     Memory: 5.2M
        CPU: 47ms
     CGroup: /system.slice/apache2.service
             ├─9406 /usr/sbin/apache2 -k start
             ├─9408 /usr/sbin/apache2 -k start
             └─9409 /usr/sbin/apache2 -k start
jm-admin@vm-team1-dvwa:~$
```

'sudo apt install apache2 -y' installs apache
Confirmed enabled and running

```
> ^C
jm-admin@vm-team1-dvwa:~$ ls -ld /var/www/html
drwxr-xr-x 2 root root 4096 Oct  1 18:09 /var/www/html
jm-admin@vm-team1-dvwa:~$ ls -la /var/www/html
total 32
drwxr-xr-x 2 root root  4096 Oct  1 18:09 .
drwxr-xr-x 3 root root  4096 Oct  1 17:58 ..
-rw-r--r-- 1 root root 10671 Oct  1 17:58 index.html
-rw-r--r-- 1 root root 10671 Oct  1 18:07 index.html.backup
jm-admin@vm-team1-dvwa:~$ curl -I http://localhost
HTTP/1.1 200 OK
Date: Thu, 01 Oct 2026 18:14:58 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Thu, 01 Oct 2026 17:58:39 GMT
ETag: "29af-65ccb2a5e69c9"
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html

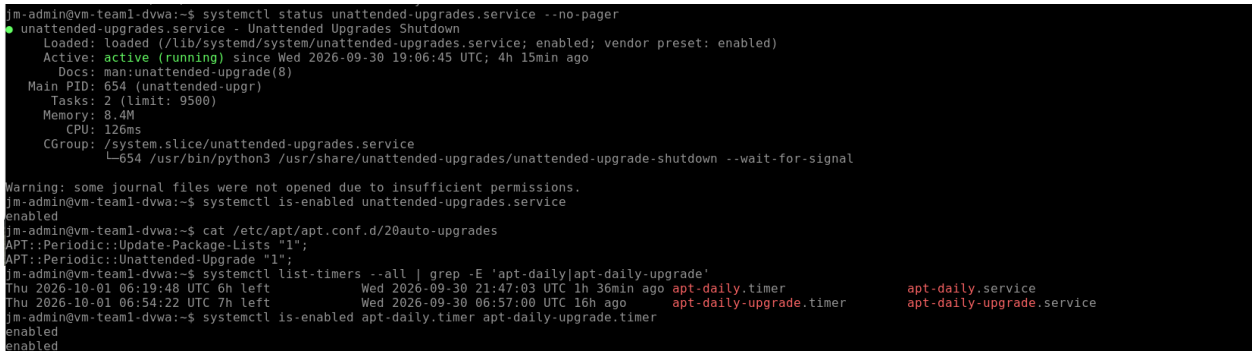
jm-admin@vm-team1-dvwa:~$ find /var/www/html -perm /002 -ls
jm-admin@vm-team1-dvwa:~$ find /var/www/html -perm /020 -ls
jm-admin@vm-team1-dvwa:~$ {
```

Default web root /var/www/html confirmed with index.html webpage
Index.html backup created and confirmed
'curl -I http://localhost' verifies webserver is up locally

The web root is owned by root:root with directory permissions of 755 (owner full read, write, and execute access, while giving others read and execute access only)
The web content files are owned by root:root with permissions of 644(owner can read and write, while others can only read it)
Confirmed no world writable and group writable files
Webroot permissions saved to ~/A3_evidence/webroot_permissions.txt

'curl -I http://localhost' verifies webserver is up locally

Enable automatic security updates



Confirmed unattended-upgrades is enabled and configured to automatically retrieve package information and install unattended updates, APT update timers were also verified.

Linux Hardening Before/After Comparison

1. SSH ROOT ACCESS
Before:
PermitRootLogin was configured as without-password

After:
PermitRootLogin no

Change:
Direct SSH access to the root account is now disabled

2. SSH PASSWORD AUTHENTICATION
Before:
PasswordAuthentication yes

After:
PasswordAuthentication no
KbdInteractiveAuthentication no

Change:
Remote SSH authentication now requires public-key authentication instead of passwords

3. SSH PUBLIC-KEY AUTHENTICATION
Before:
Administrator accounts did not have the completed key-based configuration.

After:
Authorized public keys were configured for the required named administrator accounts

Change:
Administrators can authenticate using SSH keys

4. HOST FIREWALL
Before:
UFW not enabled

After:
UFW is enabled with a default-deny incoming policy and only required application/administration ports permitted (SSH-22, HTTP-80, HTTPS-443)

Change:
Inbound network access is restricted to required services.

5. UNUSED SERVICES
Before:
open-vm-tools.service = enabled
vgauth.service = enabled
snapd.service = enabled

Snap application not required for this VM workload; both VMware services were inactive because their startup conditions were not met.

After:
open-vm-tools.service = disabled
vgauth.service = disabled
Snapd.service = disabled

Change:
Snap services and Unused VMware guest services are no longer enabled

6. SECURITY UPDATES
Before:
unattended-upgrades enabled

After:
unattended-upgrades is enabled and automatic update configuration/timers were verified.

Change:
The server has an established automatic patching mechanism.

7. LISTENING PORTS
Before:
Listening ports include 53,68,323,53,22

After:
Listening ports remained the same

Change:
Listening ports remained unchanged

8. ACCOUNTS
Before:
No other administrator accounts beside azureadmin

After:
Named administrator accounts jm-admin and dy-admin are configured with the required privileges and SSH key authentication

Change:
Administrative access is given to individual accounts

9. WEB SERVER PERMISSIONS
Before:
No web server existed

After:
Apache web server created. The Apache web root /var/www/html was reviewed. The directory was owned by root:root with permissions of 755, and the web files were owned by root:root with permissions of 644. Checks found no group or world-writable files.

Change:

Web server created and confirmed to have correct least privilege ownership and permissions for webroot and any files

Part A4. Harden the Windows Host (Domain Controller and File Server)

Run Windows Update to current and reboot
(Ran sconfig, entered '6', and updated all)

Disable unused roles, features, and services
Disabled SMB v1 and PowerShell-V2

```
PS C:\Users\azureadmin> Uninstall-WindowsFeature FS-SMB1, PowerShell-V2

Success Restart Needed Exit Code      Feature Result
------- -------------- ---------      --------------
True    No             NoChangeNeeded {}
```

Disabled other services

```
PS C:\Users\azureadmin> $services = 'Spooler','MapsBroker','lfsvc','SSDPSRV','upnphost','RemoteRegistry'
>> foreach ($s in $services) {
>>   if (Get-Service $s -ErrorAction SilentlyContinue) {
>>     Stop-Service $s -Force -ErrorAction SilentlyContinue
>>     Set-Service $s -StartupType Disabled
>>     "$s disabled"
>>   }
>> }
Spooler disabled
MapsBroker disabled
lfsvc disabled
SSDPSRV disabled
upnphost disabled
RemoteRegistry disabled
```

Service	Name	Why disable
Spooler	Print Spooler	Microsoft recommends disabling it on DCs because of the PrintNightmare vulnerability
MapsBroker	Downloaded Maps Manager	Not needed on a server
lfsvc	Geolocation Service	Not needed on a server
SSDPSRV	SSDP Discovery	Network device discovery, not needed
upnphost	UPnP Device Host	Network device discovery, not needed
RemoteRegistry	Remote Registry	Allows others to edit the registry over the

		network

Disabled NetBIOS

```
PS C:\Users\azureadmin> Get-CimInstance Win32_NetworkAdapterConfiguration -Filter "IPEnabled=True" |
>>   Invoke-CimMethod -MethodName SetTcpipNetbios -Arguments @{TcpipNetbiosOptions=2}

ReturnValue PSComputerName
----------- --------------
          0
```

Updated open ports

```
PS C:\Users\azureadmin> nmap -sV -p- 10.10.60.196
Starting Nmap 7.991 ( https://nmap.org ) at 2026-09-25 18:42 +0000
Nmap scan report for vm-team4-dc.internal.cloudapp.net (10.10.60.196)
Host is up (0.00069s latency).
Not shown: 65523 closed tcp ports (reset)
PORT      STATE    SERVICE       VERSION
135/tcp   open     msrpc         Microsoft Windows RPC
137/tcp   filtered netbios-ns
445/tcp   open     microsoft-ds?
3389/tcp  open     ms-wbt-server Microsoft Terminal Services
5985/tcp  open     http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
47001/tcp open     http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp open     unknown
49665/tcp open     unknown
49666/tcp open     unknown
49667/tcp open     unknown
49668/tcp open     unknown
49669/tcp open     unknown
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Uninstalled XPS-Viewer and AzureArcSetup

```
PS C:\Users\azureadmin> Uninstall-WindowsFeature XPS-Viewer, AzureArcSetup

Success Restart Needed Exit Code      Feature Result
------- -------------- ---------      --------------
True    Yes            SuccessRest... {Azure Arc Setup, XPS Viewer}
```

Set a strong password policy

Before:

```
PS C:\Users\azureadmin> net accounts | Tee-Object "vm-team4-dc_2026-09-30 - Password Policy Before.txt"
Force user logoff how long after time expires?:       Never
Minimum password age (days):                          0
Maximum password age (days):                          42
Minimum password length:                              0
Length of password history maintained:                None
Lockout threshold:                                    10
Lockout duration (minutes):                           10
Lockout observation window (minutes):                 10
Computer role:                                        SERVER
The command completed successfully.
```

After:

```
PS C:\Users\azureadmin> net accounts | Tee-Object "vm-team4-dc_2026-09-30 - Password Policy After.txt"
>> secedit /export /cfg C:\check.cfg; Select-String "PasswordComplexity" C:\check.cfg; Remove-Item C:\check.cfg
Force user logoff how long after time expires?:       Never
Minimum password age (days):                          1
Maximum password age (days):                          90
Minimum password length:                              14
Length of password history maintained:                24
Lockout threshold:                                    5
Lockout duration (minutes):                           15
Lockout observation window (minutes):                 15
Computer role:                                        SERVER
The command completed successfully.
```

```
C:\check.cfg:7:PasswordComplexity = 1
```

Create individual admin accounts

dy-admin pw: DY$password12345

```
PS C:\Users\azureadmin> $pw = Read-Host "Enter password for dy-admin" -AsSecureString
>> New-LocalUser -Name "dy-admin" -FullName "Dominic Yeakel (Admin)" -Description "Named admin account - Dominic Yeakel" -Password $pw
>> Add-LocalGroupMember Administrators -Member "dy-admin"
Enter password for dy-admin: ****************

Name     Enabled Description
----     ------- -----------
dy-admin True    Named admin account - Dominic Yeakel
```

jm-admin pw: JM$password12345

```
PS C:\Users\azureadmin> $pw = Read-Host "Enter password for jm-admin" -AsSecureString
>> New-LocalUser -Name "jm-admin" -FullName "Jason Man (Admin)" -Description "Named admin account - Jason Man" -Password $pw
>> Add-LocalGroupMember Administrators -Member "jm-admin"
Enter password for jm-admin: ****************

Name     Enabled Description
----     ------- -----------
jm-admin True    Named admin account - Jason Man
```

(Validated both accounts have admin rights)

New azureadmin pw: rvGIF*fK8LARE!@&bnawX6Mm

```
PS C:\Windows\system32> $pw = Read-Host "Enter new break-glass password for azureadmin" -AsSecureString
>> Set-LocalUser azureadmin -Password $pw -Description "Break-glass account - emergency use only"
Enter new break-glass password for azureadmin: ************************
```

```
Name               Enabled Description
----               ------- -----------
azureadmin            True Break-glass account - emergency use only
DefaultAccount       False A user account managed by the system.
dy-admin              True Named admin account - Dominic Yeakel
Guest                False Built-in account for guest access to the computer/domain
jm-admin              True Named admin account - Jason Man
WDAGUtilityAccount   False A user account managed and used by the system for Windows Defender Application Guard scenarios.



Name                   ObjectClass
----                   -----------
vm-team4-dc\azureadmin User
vm-team4-dc\dy-admin   User
vm-team4-dc\jm-admin   User
```

Turn on auditing for logon events, account management, privilege use, and object access

```
PS C:\Users\dy-admin> auditpol /set /category:"Logon/Logoff" /success:enable /failure:enable
>> auditpol /set /category:"Account Logon" /success:enable /failure:enable
>> auditpol /set /category:"Account Management" /success:enable /failure:enable
>> auditpol /set /category:"Privilege Use" /success:enable /failure:enable
>> auditpol /set /category:"Object Access" /success:enable /failure:enable
The command was successfully executed.
The command was successfully executed.
The command was successfully executed.
The command was successfully executed.
The command was successfully executed.
```

Enable the Windows firewall with least-privilege inbound rules

```
PS C:\Users\dy-admin> Set-NetFirewallProfile -Profile Domain,Private,Public -Enabled True `
>>    -DefaultInboundAction Block -DefaultOutboundAction Allow `
>>    -LogBlocked True -LogAllowed False -LogMaxSizeKilobytes 16384
```

(Default Deny)

```
PS C:\Users\dy-admin> $mgmt = "10.10.40.0/26"
>>
>> Get-NetFirewallRule -DisplayGroup "Remote Desktop" | Set-NetFirewallRule -RemoteAddress $mgmt
>> Get-NetFirewallRule -DisplayGroup "Windows Remote Management" | Set-NetFirewallRule -RemoteAddress $mgmt
```

(Limits management ports to Bastion)

```
PS C:\Users\dy-admin> Disable-NetFirewallRule -DisplayName "Remote Desktop - Shadow (TCP-In)"
```

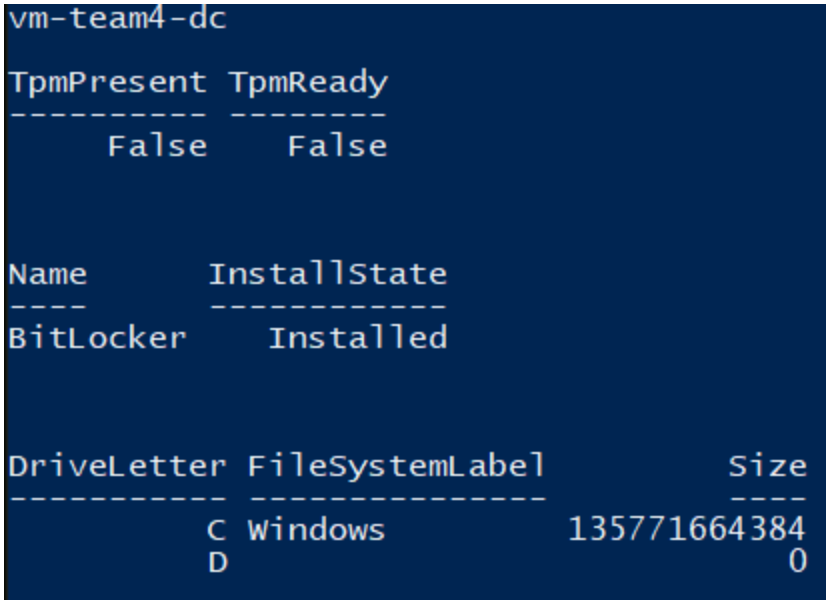
(Disabled rule that lets an admin view or take over another user's active RDP session)

```
Name    Enabled DefaultInboundAction DefaultOutboundAction
----    ------- -------------------- --------------------
Domain     True                Block                Allow
Private    True                Block                Allow
Public     True                Block                Allow
```

```
Rule                                  Enabled RemoteAddress
----                                  ------- -------------
Windows Remote Management (HTTP-In)      True 10.10.40.0/255.255.255.192
Remote Desktop - Shadow (TCP-In)         True 10.10.40.0/255.255.255.192
Windows Remote Management (HTTP-In)      True 10.10.40.0/255.255.255.192
Remote Desktop - User Mode (TCP-In)      True 10.10.40.0/255.255.255.192
Remote Desktop - User Mode (UDP-In)      True 10.10.40.0/255.255.255.192
```

(Verification)

Plan BitLocker as the data-at-rest control for the file server volume



BitLocker plan: file server data volume

Status: Planned. The file server volume doesn't exist yet. Encryption will be applied when the file server volume is created.

Findings (vm-team4-dc, 2026-09-30)

No virtual TPM (TpmPresent: False), so BitLocker can't be enabled from inside the VM.
BitLocker feature: installed.
Volumes: C: (OS, about 126 GB) and D: (empty virtual DVD drive). There's no data volume.

Objective
Protect file share data at rest so it can't be read if the disk or a snapshot is copied or accessed outside the VM.

Method: Azure Disk Encryption (ADE)
Since the VM has no virtual TPM, BitLocker will be enabled through Azure Disk Encryption. Azure runs BitLocker inside the VM and stores the encryption keys in Azure Key Vault. If the file server is built as a new VM, it should be deployed as a Trusted Launch VM with vTPM enabled, which also allows BitLocker to be managed from inside the VM.

Settings

Setting	Value
Volumes	Data volume (F:) and OS volume (C:)
Algorithm	XTS-AES 256-bit
Key storage	Azure Key Vault
Key Vault access	Named admin accounts only

Recovery keys	Stored in Key Vault. After promotion, also backed up to Active Directory

Implementation steps

Snapshot the VM's disks.
Add and format a data disk as F: for the file shares.
Create a Key Vault with Azure Disk Encryption for volume encryption enabled.
Enable encryption on OS and data disks: VM → Disks → Additional settings.
Verify with Get-BitLockerVolume. Expected result: FullyEncrypted, XtsAes256, Protection On.

Existing protection
Azure already encrypts all managed disks at the storage layer with Microsoft-managed keys.
BitLocker adds a second layer inside the guest OS.

Risks

Lost recovery keys mean lost data, so Key Vault access must be protected and backed up.
Encryption adds CPU and disk load while it runs, so schedule it outside busy periods.

Part A5. Stand Up Active Directory and the Bank File Share

Install the Active Directory Domain Services role and promote vm-team4-dc to a domain controller for ironbridge.local
DSRM password: DSRMpassword$12345

```
DNSRoot     : ironbridge.local
NetBIOSName : IRONBRIDGE
DomainMode  : Windows2016Domain
PDCEmulator : vm-team4-dc.ironbridge.local



Name       Status
----       ------
ADWS      Running
DNS       Running
KDC       Running
Netlogon  Running
NTDS      Running
```

```
SamAccountName Enabled UserPrincipalName         Groups
-------------- ------- -----------------         ------
azureadmin       True                            Group Policy Creator Owners, Domain Admins, Enterprise Admins, Schema Admins, Administrators
dy-admin         True dy-admin@ironbridge.local  Domain Admins, Administrators
Guest           False                            Guests
jm-admin         True jm-admin@ironbridge.local  Domain Admins, Administrators
krbtgt          False                            Denied RODC Password Replication Group
```

Create organizational units, security groups, and a small set of user accounts that represent bank staff

Domain password policy

```
MinPasswordLength         : 14
ComplexityEnabled         : True
PasswordHistoryCount      : 24
MaxPasswordAge            : 90.00:00:00
MinPasswordAge            : 1.00:00:00
LockoutThreshold          : 5
LockoutDuration           : 00:15:00
LockoutObservationWindow  : 00:15:00
```

Initial password for new users: Simplepassword$12345

```
Name              DistinguishedName
----              -----------------
Admin Accounts    OU=Admin Accounts,OU=Ironbridge,DC=ironbridge,DC=local
Branch Operations OU=Branch Operations,OU=Staff,OU=Ironbridge,DC=ironbridge,DC=local
Compliance        OU=Compliance,OU=Staff,OU=Ironbridge,DC=ironbridge,DC=local
Finance           OU=Finance,OU=Staff,OU=Ironbridge,DC=ironbridge,DC=local
Groups            OU=Groups,OU=Ironbridge,DC=ironbridge,DC=local
Ironbridge        OU=Ironbridge,DC=ironbridge,DC=local
IT                OU=IT,OU=Staff,OU=Ironbridge,DC=ironbridge,DC=local
Lending           OU=Lending,OU=Staff,OU=Ironbridge,DC=ironbridge,DC=local
Servers           OU=Servers,OU=Ironbridge,DC=ironbridge,DC=local
Staff             OU=Staff,OU=Ironbridge,DC=ironbridge,DC=local
Workstations      OU=Workstations,OU=Ironbridge,DC=ironbridge,DC=local



Name               GroupScope GroupCategory
----               ---------- -------------
GG-Branch-Managers     Global      Security
GG-Compliance          Global      Security
GG-Finance             Global      Security
GG-IT-Support          Global      Security
GG-Loan-Officers       Global      Security
GG-Tellers             Global      Security



SamAccountName Name            Title              Department        Groups
-------------- ----            -----              ----------        ------
dy-admin       dy-admin                                             Domain Admins, Administrators
jm-admin       jm-admin                                             Domain Admins, Administrators
mjohnson       Marcus Johnson  Teller             Branch Operations GG-Tellers
ppatel         Priya Patel     Branch Manager     Branch Operations GG-Branch-Managers
schen          Sarah Chen      Teller             Branch Operations GG-Tellers
lkim           Laura Kim       Compliance Officer Compliance        GG-Compliance
jwalsh         James Walsh     Accountant         Finance           GG-Finance
tbrennan       Tom Brennan     IT Support Analyst IT                GG-IT-Support
dokafor        David Okafor    Loan Officer       Lending           GG-Loan-Officers
erodriguez     Emily Rodriguez Loan Officer       Lending           GG-Loan-Officers
```

<u>OU Structure</u>

Ironbridge.local (Domain)

- Ironbridge (Bank root OU)
    - Staff
        - Branch operations
        - Lending
        - Finance
        - Compliance
        - IT
    - Groups

- Admin accounts
- Workstations
- Servers

Create the file share that will hold synthetic customer and transaction records, this is your data server

Access design

Folder	Read/Write	Read-only
Customers	Tellers, Branch Managers, Loan Officers	Compliance
Transactions	Tellers, Branch Managers, Finance	Compliance, Loan Officers

```
Name                  : BankData
Path                  : C:\Shares\BankData
Description           : Synthetic customer and transaction records
FolderEnumerationMode : AccessBased
EncryptData           : True



AccountName                     AccessControlType AccessRight
-----------                     ----------------- -----------
IRONBRIDGE\Domain Admins                    Allow        Full
NT AUTHORITY\Authenticated Users            Allow      Change


C:\Shares\BankData IRONBRIDGE\DL-Transactions-RO:(RX)
                   IRONBRIDGE\DL-Transactions-RW:(RX)
                   IRONBRIDGE\DL-Customers-RO:(RX)
                   IRONBRIDGE\DL-Customers-RW:(RX)
                   BUILTIN\Administrators:(OI)(CI)(F)
                   NT AUTHORITY\SYSTEM:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Shares\BankData\Customers IRONBRIDGE\DL-Customers-RO:(OI)(CI)(RX)
                             IRONBRIDGE\DL-Customers-RW:(OI)(CI)(M)
                             BUILTIN\Administrators:(I)(OI)(CI)(F)
                             NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Shares\BankData\Transactions IRONBRIDGE\DL-Transactions-RO:(OI)(CI)(RX)
                                IRONBRIDGE\DL-Transactions-RW:(OI)(CI)(M)
                                BUILTIN\Administrators:(I)(OI)(CI)(F)
                                NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
DL-Customers-RO: GG-Compliance
DL-Customers-RW: GG-Loan-Officers, GG-Branch-Managers, GG-Tellers
DL-Transactions-RO: GG-Compliance, GG-Loan-Officers
DL-Transactions-RW: GG-Finance, GG-Branch-Managers, GG-Tellers
```

Apply NTFS and share permissions with least privilege, no broad Everyone access, access by group only

```
AccountName                          AccessControlType AccessRight
-----------                          ----------------- -----------
IRONBRIDGE\Domain Admins                         Allow        Full
IRONBRIDGE\DL-Customers-RW                       Allow      Change
IRONBRIDGE\DL-Transactions-RW                    Allow      Change
IRONBRIDGE\DL-Customers-RO                       Allow        Read
IRONBRIDGE\DL-Transactions-RO                    Allow        Read
```

Populate the share with clearly synthetic sample data only, never real personal or financial data

```
FullName                                                Length LastWriteTime
--------                                                ------ -------------
C:\Shares\BankData\README_SYNTHETIC_DATA.txt                297 10/2/2026 6:25:26 PM
C:\Shares\BankData\Customers\README_SYNTHETIC_DATA.txt      297 10/2/2026 6:25:26 PM
C:\Shares\BankData\Customers\SYNTHETIC_customers.csv      10018 10/2/2026 6:25:26 PM
C:\Shares\BankData\Transactions\README_SYNTHETIC_DATA.txt    297 10/2/2026 6:25:26 PM
C:\Shares\BankData\Transactions\SYNTHETIC_transactions.csv 70562 10/2/2026 6:25:26 PM



Customers: 50
Transactions: 500

CustomerID FirstName LastName    Email                          Phone    State AccountNumber DataClassification
---------- --------- --------    -----                          -----    ----- ------------- ------------------
SYN-C00001 Quinn     Dunmore     quinn.dunmore1@example.com     555-0199 ZZ    SYN-A10000001 SYNTHETIC - NOT REAL
SYN-C00002 Casey     Elmsworth   casey.elmsworth2@example.com   555-0131 ZZ    SYN-A10000002 SYNTHETIC - NOT REAL
SYN-C00003 Skyler    Brightwater skyler.brightwater3@example.com 555-0106 ZZ    SYN-A10000003 SYNTHETIC - NOT REAL



C:\Shares\BankData\Customers\SYNTHETIC_customers.csv IRONBRIDGE\DL-Customers-RO:(I)(RX)
                                                     IRONBRIDGE\DL-Customers-RW:(I)(M)
                                                     BUILTIN\Administrators:(I)(F)
                                                     NT AUTHORITY\SYSTEM:(I)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Shares\BankData\Transactions\SYNTHETIC_transactions.csv IRONBRIDGE\DL-Transactions-RO:(I)(RX)
                                                          IRONBRIDGE\DL-Transactions-RW:(I)(M)
                                                          BUILTIN\Administrators:(I)(F)
                                                          NT AUTHORITY\SYSTEM:(I)(F)
```

Permission model

```
Name                  : BankData
Path                  : C:\Shares\BankData
FolderEnumerationMode : AccessBased
EncryptData           : True




AccountName                   AccessRight
-----------                   -----------
IRONBRIDGE\Domain Admins             Full
IRONBRIDGE\DL-Customers-RW         Change
IRONBRIDGE\DL-Transactions-RW      Change
IRONBRIDGE\DL-Customers-RO           Read
IRONBRIDGE\DL-Transactions-RO        Read



C:\Shares\BankData IRONBRIDGE\DL-Transactions-RO:(RX)
                   IRONBRIDGE\DL-Transactions-RW:(RX)
                   IRONBRIDGE\DL-Customers-RO:(RX)
                   IRONBRIDGE\DL-Customers-RW:(RX)
                   BUILTIN\Administrators:(OI)(CI)(F)
                   NT AUTHORITY\SYSTEM:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Shares\BankData\Customers IRONBRIDGE\DL-Customers-RO:(OI)(CI)(RX)
                             IRONBRIDGE\DL-Customers-RW:(OI)(CI)(M)
                             BUILTIN\Administrators:(I)(OI)(CI)(F)
                             NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Shares\BankData\Transactions IRONBRIDGE\DL-Transactions-RO:(OI)(CI)(RX)
                                IRONBRIDGE\DL-Transactions-RW:(OI)(CI)(M)
                                BUILTIN\Administrators:(I)(OI)(CI)(F)
                                NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
DL-Customers-RO: GG-Compliance
DL-Customers-RW: GG-Loan-Officers, GG-Branch-Managers, GG-Tellers
DL-Transactions-RO: GG-Compliance, GG-Loan-Officers
DL-Transactions-RW: GG-Finance, GG-Branch-Managers, GG-Tellers
Domain Admins: azureadmin, dy-admin, jm-admin
GG-Branch-Managers: ppatel
GG-Compliance: lkim
GG-Finance: jwalsh
GG-IT-Support: tbrennan
GG-Loan-Officers: dokafor, erodriguez
GG-Tellers: schen, mjohnson
```

Part A6. Build Internal CA and Enable TLS

Install Active Directory Certificate Services on your DC as the Ironbridge internal Certificate Authority, or use the shared class CA if your instructor directs you to

```
Name      Status StartType
----      ------ ---------
CertSvc Running Automatic



CA name: Ironbridge Root CA
CertUtil: -CAInfo command completed successfully.
Connecting to vm-team4-dc.ironbridge.local\Ironbridge Root CA ...
Server "Ironbridge Root CA" ICertRequest2 interface is alive (0ms)
CertUtil: -ping command completed successfully.


Subject  : CN=Ironbridge Root CA, DC=ironbridge, DC=local
Issuer   : CN=Ironbridge Root CA, DC=ironbridge, DC=local
NotAfter : 10/2/2036 6:39:28 PM
Template :

Subject  : DC=Windows Azure CRP Certificate Generator
Issuer   : DC=Windows Azure CRP Certificate Generator
NotAfter : 9/25/2027 5:19:48 AM
Template :




ComputerName                RemotePort TcpTestSucceeded
------------                ---------- ----------------
vm-team4-dc.ironbridge.local        636             True
```

Generate a certificate signing request for your web service on the Linux host

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl req -in ironbridge-web.csr -noout -text > ~/A6_evidence/csr_details.txt
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ cat ~/A6_evidence/tls/ironbridge-web.csr
-----BEGIN CERTIFICATE REQUEST-----
MIIDEzCCAfsCAQAwfTELMAkGA1UEBhMCVVMxFTATBgNVBAgMDFBlbm5zeWx2YW5p
YTEhMB8GA1UECgwYSXJvbmJyaWRnZSBOYXRpb25hbCBCYW5rMQswCQYDVQQLDAJJ
VDEnMCUGA1UEAwwedm0tdGVhbTQtZHZ3YS5pcm9uYnJpZGdlLmxvY2FsMIIBIjAN
BgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAouqVoqUi7K3sJygDuSoscx8KYSyU
A7H8VLJOWBoidSHjJG4Ll2Jr3yX7RjLO4oW4D1uP58m8tE5MHaaoDGzZsDqykm22
9h5184Cqmv3SEIhxY2wRTAlKxy378u1Qn4XyBUsJOXvhPDliJRA6GMliFqjIUopo
GGFyZ5wZAfpex7sysuGlTALPhO6/6LhdP3xK/aRrE7ELv1H7o4Zc4ymQAxpibw/K
puXKV26r3ITEI3UU2zbOxoS/mO6R+nTNxctRtxyuqg3ilhXK2aXuTIr3dw5SwRD5
rDNbuR6y37Z7fjPCX655FfRDDmQRYCUohqah5Hl434ewdsZzYxqrmyKP3QIDAQAB
oFEwTwYJKoZIhvcNAQkOMUIwQDA+BgNVHREENzA1gh52bS10ZWFtNC1kdndhLmly
b25icmlkZ2UubG9jYWyCDXZtLXRlYW00LWR2d2GHBAoKPMUwDQYJKoZIhvcNAQEL
BQADggEBAJEe6IYb1kxC7/MAvV4agj+bfRBeQdJfzP4VfQQXvnIc0rDX0ZxyYjzo
Z/pF8U5st7mlFBo3ZCsttOChuJBIV6CZJM+N4BpAxKbBd0NjYMt1X8MokZQk/znp
uSkO+PXUiydxgK/NYAsM6l3As+ggQx3r7DraMu74W8vc+j8pGlX4FPNB50WEUQPb
uCQWZeDYAVaJdnm7IP8jvYv3xPDaNGLXKauvmgRC6/tMbob7p76mr1qCHEKOETnY
aSSBUJwcNU5qPJ71AIwG5tMrhl09Aknv3Bb9U6KHYfg6fOdIpBFdf/8pc0r/dvhS
YePfOpH+iFfA8sldFM/l5PM7NRv9/ws=
-----END CERTIFICATE REQUEST-----
```

Certificate signing request created through openssl, and saved to ~/A6_evidence/csr_details.txt

Issue the TLS certificate from the CA and install it on the web server

```
PS C:\Users\dy-admin> certreq -submit -attrib "CertificateTemplate:WebServer" `
>>   -config "vm-team4-dc.ironbridge.local\Ironbridge Root CA" `
>>   .\ironbridge-web.csr .\ironbridge-web.cer
RequestId: 3
RequestId: "3"
Certificate retrieved(Issued) Issued
PS C:\Users\dy-admin> certutil -dump .\ironbridge-web.cer | Select-String "Issuer:|Subject:|CN=|DNS Name|NotAfter|Template" |
>>   Tee-Object "vm-team4-dc_2026-10-02 - Web Certificate.txt"

Issuer:
    CN=Ironbridge Root CA
 NotAfter: 10/1/2028 6:53 PM
Subject:
    CN=vm-team4-dvwa.ironbridge.local
        DNS Name=vm-team4-dvwa.ironbridge.local
        DNS Name=vm-team4-dvwa
                    URL=ldap:///CN=Ironbridge Root CA,CN=vm-team4-dc,CN=CDP,CN=Public Key
Services,CN=Services,CN=Configuration,DC=ironbridge,DC=local?certificateRevocationList?base?objectClass=cRLDistributionPoint (ldap:///CN=Ironbridge%20Root%20CA,CN=vm-team4-dc,CN=CDP,CN=Publ
ic%20Key%20Services,CN=Services,CN=Configuration,DC=ironbridge,DC=local?certificateRevocationList?base?objectClass=cRLDistributionPoint)
                URL=ldap:///CN=Ironbridge Root CA,CN=AIA,CN=Public Key Services,CN=Services,CN=Configuration,DC=ironbridge,DC=local?cACertificate?base?objectClass=certificationAuthority
(ldap:///CN=Ironbridge%20Root%20CA,CN=AIA,CN=Public%20Key%20Services,CN=Services,CN=Configuration,DC=ironbridge,DC=local?cACertificate?base?objectClass=certificationAuthority)
    Certificate Template Name (Certificate Type)
```

CA takes request and creates web server and root certificate

```
  GNU nano 6.2                                                                ironbridge-web.crt
-----BEGIN CERTIFICATE-----
MIIG2DCCBMCgAwIBAgITSwAAAAN5lM9Ypz9lXAAAAAAAAzANBgkqhkiG9w0BAQsF
ADBQMRUwEwYKCZImiZPyLGQBGRYFbG9jYWwxGjAYBgoJkiaJk/IsZAEZFgppcm9u
YnJpZGdlMRswGQYDVQQDExJJcm9uYnJpZGdlIFJvb3QgQ0EwHhcNMjYxMDAyMTg1
MzI1WhcNMjgxMDAxMTg1MzI1WjB9MQswCQYDVQQGEwJVUzEVMBMGA1UECBMMUGVu
bnN5bHZhbmlhMSEwHwYDVQQKExhJcm9uYnJpZGdlIE5hdGlvbmFsIEJhbmsxCzAJ
BgNVBAsTAklUMScwJQYDVQQDEx52bS10ZWFtNC1kdndhLmlyb25icmlkZ2UubG9j
YWwwggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCi6pWipSLsrewnKAO5
KixzHwphLJQDsfxUsk5YGiJ1IeMkbguXYmvfJftGMs7ihbgPW4/nyby0TkwdpqgM
bNmwOrKSbbb2HnXzgKqa/dIQiHFjbBFMCUrHLfvy7VCfhfIFSwk5e+E8OWIlEDoY
yWIWqMhSimgYYXJnnBkB+l7HuzKy4aVMAs+E7r/ouF0/fEr9pGsTsQu/Ufujhlzj
KZADGmJvD8qm5cpXbqvchMQjdRTbNs7GhL+Y7pH6dM3Fy1G3HK6qDeKWFcrZpe5M
ivd3DlLBEPmsM1u5HrLftnt+M8JfrnkV9EMOZBFgJSiGpqHkeXjfh7B2xnNjGqub
Io/dAgMBAAGjggJ8MIICeDA+BgNVHREENzA1gh52bS10ZWFtNC1kdndhLmlyb25i
cmlkZ2UubG9jYWyCDXZtLXRlYW00LWR2d2GHBAoKPMUwHQYDVR0OBBYEFM9kyXKb
viU6tb0g0CTtiZMHwVUmMB8GA1UdIwQYMBaAFNgxIcYSDx+w5nyZ/nyrBHy3RbZu
MIHdBgNVHR8EgdUwgdIwgc+ggcygcmGgcZsZGFwOi8vL0NOPUlyb25icmlkZ2Ul
MjBSb290JTIwQ0EsQ049dm0tdGVhbTQtZGMsQ049Q0RQLENOPVB1YmxpYyUyMEtl
eSUyMFNlcnZpY2VzLENOPVNlcnZpY2VzLENOPUNvbmZpZ3VyYXRpb24sREM9aXJv
bmJyaWRnZSxEQz1sb2NhbD9jZXJ0aWZpY2F0ZVJldm9jYXRpb25MaXN0P2Jhc2U/
b2JqZWN0Q2xhc3M9Y1JMRGlzdHJpYnV0aW9uUG9pbnQwgc0GCCsGAQUFBwEBBIHA
MIG9MIG6BggrBgEFBQcwAoaBrWxkYXA6Ly8vQ049SXJvbmJyaWRnZSUyMFJvb3Ql
MjBDQSxDTj1BSUEsQ049UHVibGljJTIwS2V5JTIwU2VydmljZXMsQ049U2Vydmlj
ZXMsQ049Q29uZmlndXJhdGlvbixEQz1pcm9uYnJpZGdlLERDPWxvY2FsP2NBQ2Vy
dGlmaWNhdGU/YmFzZT9vYmplY3RDbGFzcz1jZXJ0aWZpY2F0aW9uQXV0aG9yaXR5
MCEGCSsGAQQBgjcUAgQUHhIAVwBlAGIAUwBlAHIAdgBlAHIwDgYDVR0PAQH/BAQD
AgWgMBMGA1UdJQQMMAoGCCsGAQUFBwMBMA0GCSqGSIb3DQEBCwUAA4ICAQAl82O1
j5Lrfv4V/kgm5Y5yhhPRqbV6flfwwHUCtuTo8UuDWnbe2QTyULceuH7KjesEjteO
NviC/ZtY9dFFshgIXDl58GcPZ0VHqJE3LQ07vqJbyoQkEb/WaUhjQeDS+Ssoi5Js
aLWPOdLg2V8jEGwE6hFk+55pbcHLpSJeoJxI8aOuimjdAuPrq+j2ys6wQ6aaCg/N
tcHPTxjdmvan+To+Apqh0tTNeTaEG22bsz4Au6qXUvYuQ0m/sBWSt34k+rNwLEvz
aEKXDZtOgbWiClAoSR4dUT6Pq7eqCI5saj+AG3txxhjtIDQPfVJkKW3ba41WpXlz
Iizl9XxeFFei6uthNKRqEtseyp1YLf3oFfTzPPWDAZkYiLyij9dEfmATc7+gwNOt
Kd9JyvhHHvqxhsrwQh6e3iaDxJswZNmVgTi12rCOhUi4Wm8eVZMTkn69XKw44fLT
05SoNKCGCddw5/B9hx0SjXsOyxctdbZzkF0CigPiZ7H79CTspRRbyu815smHRX+M
B5OloisxjPzDdTza/oenP4M1xEFRyyuu1IxAgB5Y8dC9+p5PC/QEgSLtFzM7GZ7B
GUIv4cNUGMGDUsjj3cqKfLn5Jwh0r5XlLvwP6LKW3bbHKCcBK2FCbZcdlJ7l8v+e
eUEFjUzs02tiR74eR6zIiYygHnDj3T/PEr2/Qw==
-----END CERTIFICATE-----
```

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl x509 -in ~/A6_evidence/tls/ironbridge-web.crt -noout -subject -issuer -dates
subject=C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
issuer=DC = local, DC = ironbridge, CN = Ironbridge Root CA
notBefore=Oct  2 18:53:25 2026 GMT
notAfter=Oct  1 18:53:25 2028 GMT
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
```

CA verified issued web server certificate placed onto webserver/jumpbox(linux machine)

```
 GNU nano 6.2                                                ironbridge-root-ca.crt
-----BEGIN CERTIFICATE-----
MIIFezCCA2OgAwIBAgIQH5Ph42el1J5FFZAEwiczvTANBgkqhkiG9w0BAQsFADBQ
MRUwEwYKCZImiZPyLGQBGRYFbG9jYWwxGjAYBgoJkiaJk/IsZAEZFgppcm9uYnJp
ZGdlMRswGQYDVQQDExJJcm9uYnJpZGdlIFJvb3QgQ0EwHhcNMjYxMDAyMTgyOTI5
WhcNMzYxMDAyMTgzOTI4WjBQMRUwEwYKCZImiZPyLGQBGRYFbG9jYWwxGjAYBgoJ
kiaJk/IsZAEZFgppcm9uYnJpZGdlMRswGQYDVQQDExJJcm9uYnJpZGdlIFJvb3Qg
Q0EwggIiMA0GCSqGSIb3DQEBAQUAA4ICDwAwggIKAoICAQDOnF+crdbW1Ep4DnA6
x0ZUevNvvVYpfgS8u3BQOrdmVE1ODf5JPy4l2hVP3X7S47e4+3AWIYoswqFysBbr
EzPzmiPyxp+TbJKHaOhkEDI6QuZFRnwRCN/4/If6l1YPmG480Rm+iMi9HCRvzOFo
jG8/51hHrGfMXoB48KmeVPVf1yQ1Det9yiLJp7MGBGdPbxbSPRPU7uazq3YXDKTi
BMvcDx9RNMuCEIJVpVTrFGwqSVy+WISdodS63XTlt7zDz+BbZVSZJCZJHFckY+M1
jjrSi5vUYxGSpohRcEbZOXanzUkKGJXVlzh/21Al/02H5LlUsEwEMN+NGi+/YZjy
8kWER1fxylTI2XWQpwCx3ljLA7dHD6rBCqwWDUVWT2aEs3aUzwhQJ+KATQoAX6HC
FKpIE+/WbbcVcxsxKtQ9O4DWmg+hM4ubfKIScQMjwf7uw0YtmZ8no91TbrSQJ2wh
ZY5N1OClamEa5dGMBJYDxTzmzN6+9HFCle20w8v2+bfv3bZBVp0afVhDvdu0fExp
f5mWydr91VFFE+ynsG4jP1LLlY0p6w7xxlsPBOimM5AIgh3kt9QilQws07ZEPIs+
UzAdNQxyK94RJtsz4tDTd3gSdu8W5VTm8T8LMq2RiC0Q41HHxKz47aHfJSmyqvHy
x0HBEVbVFsITP+TEV00sbJPT1QIDAQABo1EwTzALBgNVHQ8EBAMCAYYwDwYDVR0T
AQH/BAUwAwEB/zAdBgNVHQ4EFgQU2DEhxhIPH7DmfJn+fKsEfLdFtm4wEAYJKwYB
BAGCNxUBBAMCAQAwDQYJKoZIhvcNAQELBQADggIBAJHXXpj1rqdabICnFYXnIqFE
8yuKV64csSxEhOCYLv8xy34CsKSCq0qUIxwaXzArPT1eUnOxVANJphc1UzIus44Q
9YkUyWD8QdxNj9SnM3/sV4GzrKd/UC1/OQUdtCOf5JrFzk6rsmGTYzq4VYsCVYc9
gw2b3P4Qg70fOk/myKppW3SUMy6EgxJTxoKK+QlH5qBsbBSJFpNFYC5RPZJ1uFMe
ZAu9tMmBMSTYEdzs+DTpLfIha2uaLElvvwR7sT6pA2o+2iASUoryRAatdDxGYzZj
x89KT+5Prm8sboeV75PNT/x8NoIvUiElV0SgW/vg9OFyT3CBz39EbsEOJU/uLViU
qUWHqZ8rN84W5RORDwDS2TZ8kJ99WS9ax1lMIx5bsSYSnT0fcyEG9ygtB2gcD55y
2lJh03+cxRGrHTVbJRD8qHL0vuNKFjDpkcVon6hoo13M1Di4AT8TWfbdjKh5iTmw
5eQ/HO9OaUjyDO1q6KeJxcCYfindreBwJv05A/QYcfLu+86vCxz4y2f9FNKu6mwF
meX3gdrtfq7nI++HOTirggaQAEFqYmysu0LWDmP3QlUV/RLvBIpyIh0xIP2QZzJc
/jtamD/h53wv/2/yx8oZLzVH2bXgk4Yv0+beWvGeLzAH9j1WKbCjR87m48BCX580
LzGj8zl0XAprTTPBL4/U
-----END CERTIFICATE-----
```

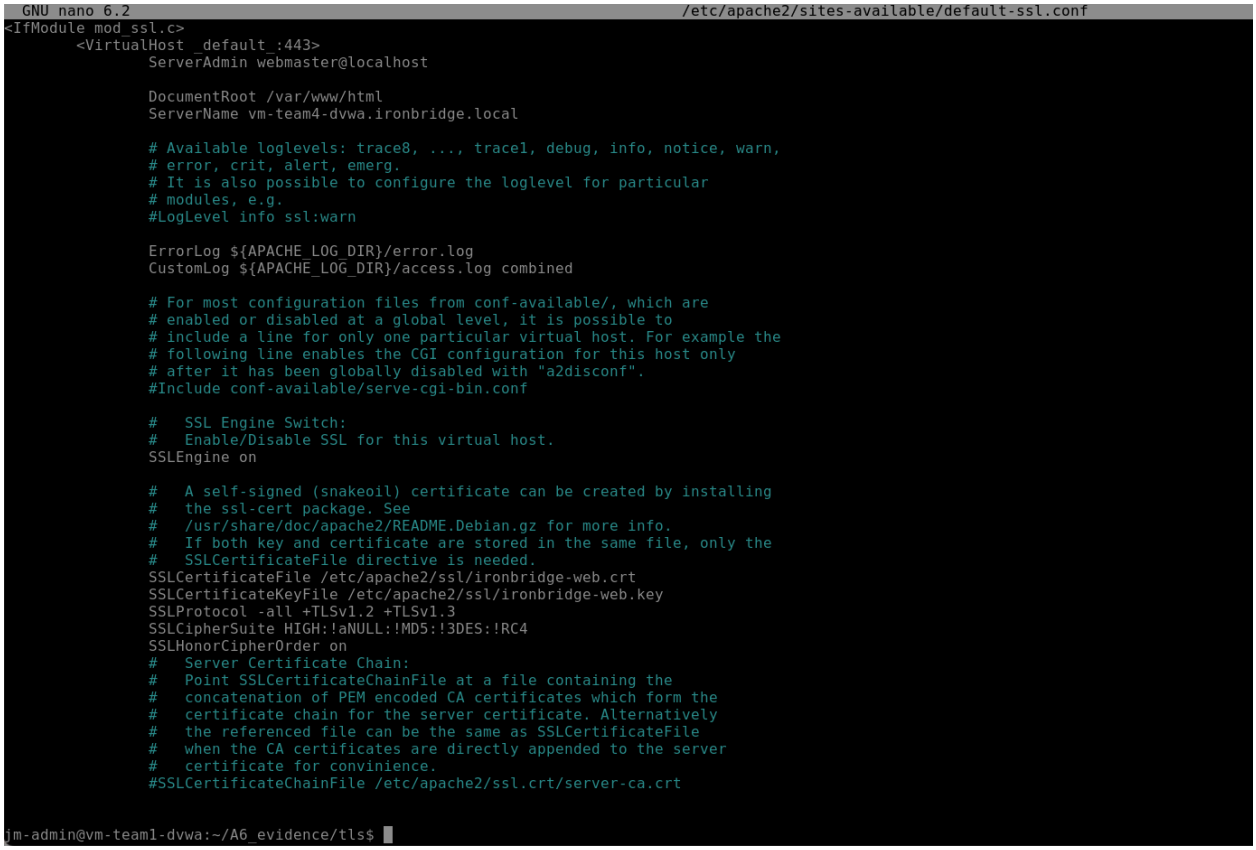
```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl x509 -in ironbridge-root-ca.crt -noout -subject -issuer
subject=DC = local, DC = ironbridge, CN = Ironbridge Root CA
issuer=DC = local, DC = ironbridge, CN = Ironbridge Root CA
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
```

CA verified issued root certificate placed onto webserver/jumpbox(linux machine)

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ ls -l
total 16
-rw-rw-r-- 1 jm-admin jm-admin 1959 Oct  2 19:40 ironbridge-root-ca.crt
-rw-rw-r-- 1 jm-admin jm-admin 2434 Oct  2 19:33 ironbridge-web.crt
-rw-rw-r-- 1 jm-admin jm-admin 1143 Oct  2 18:48 ironbridge-web.csr
-rw------- 1 jm-admin jm-admin 1704 Oct  2 18:45 ironbridge-web.key
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl verify -CAfile ironbridge-root-ca.crt ironbridge-web.crt
ironbridge-web.crt: OK
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
```

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo mkdir -p /etc/apache2/ssl
[sudo] password for jm-admin:
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo cp ~/A6_evidence/tls/ironbridge-web.crt /etc/apache2/ssl/
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo cp ~/A6_evidence/tls/ironbridge-web.key /etc/apache2/ssl/
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo chown root:root /etc/apache2/ssl/ironbridge-web.*
sudo chmod 644 /etc/apache2/ssl/ironbridge-web.crt
sudo chmod 600 /etc/apache2/ssl/ironbridge-web.keyjm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo ls -l /etc/apache2/ssl
total 8
-rw-r--r-- 1 root root 2434 Oct  2 19:52 ironbridge-web.crt
-rw------- 1 root root 1704 Oct  2 19:53 ironbridge-web.key
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
```

‘sudo mkdir -p /etc/apache2/ssl’ creates apache ssl directory
‘sudo cp ~/A6_evidence/tls/ironbridge-web.crt /etc/apache2/ssl/’ makes copy of of server certificate ironbridge-web.crt in apache ssl directory
‘sudo cp ~/A6_evidence/tls/ironbridge-web.key /etc/apache2/ssl/’ copies the private key over as well



‘sudo a2enmod ssl’ and ‘sudo a2ensite default-ssl’ enable apache SSL
‘sudo nano /etc/apache2/sites-available/default-ssl.conf’ edits HTTPS virtual host 443 adding:

ServerName vm-team4-dvwa.ironbridge.local

SSLEngine on

SSLCertificateFile /etc/apache2/ssl/ironbridge-web.crt
SSLCertificateKeyFile /etc/apache2/ssl/ironbridge-web.key

SSLProtocol -all +TLSv1.2 +TLSv1.3
SSLCipherSuite HIGH:!aNULL:!MD5:!3DES:!RC4
SSLHonorCipherOrder on

This configured Apache to use the web server certificate and corresponding private key for HTTPS
It disables anonymous authentication, MD5, 3DES, and RC4 cipher classes and disables legacy TLS, in favor of the modern versions 1.2 and 1.3

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo apache2ctl configtest
Syntax OK
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo systemctl restart apache2
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ systemctl status apache2 --no-pager
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
     Active: active (running) since Fri 2026-10-02 20:04:57 UTC; 10s ago
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 14234 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 14238 (apache2)
      Tasks: 55 (limit: 9500)
     Memory: 6.8M
        CPU: 53ms
     CGroup: /system.slice/apache2.service
             ├─14238 /usr/sbin/apache2 -k start
             ├─14239 /usr/sbin/apache2 -k start
             └─14240 /usr/sbin/apache2 -k start
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo ss -tulpn | grep ':443'
tcp   LISTEN 0      511                *:443            *:*    users:(("apache2",pid=14240,fd=6),("apache2",pid=14239,fd=6),("apache2",pid=14238,fd=6))
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
```

Apache confirmed listening on TCP 443

Configure the web server for HTTPS and redirect HTTP to HTTPS

```
 GNU nano 6.2                                                  /etc/apache2/sites-available/000-default.conf
<VirtualHost *:80>
        # The ServerName directive sets the request scheme, hostname and port that
        # the server uses to identify itself. This is used when creating
        # redirection URLs. In the context of virtual hosts, the ServerName
        # specifies what hostname must appear in the request's Host: header to
        # match this virtual host. For the default virtual host (this file) this
        # value is not decisive as it is used as a last resort host regardless.
        # However, you must set it for any further virtual host explicitly.
        #ServerName www.example.com

        ServerAdmin webmaster@localhost
        DocumentRoot /var/www/html

        ServerName vm-team4-dvwa.ironbridge.local
        Redirect permanent / https://vm-team4-dvwa.ironbridge.local/

        # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
        # error, crit, alert, emerg.
        # It is also possible to configure the loglevel for particular
        # modules, e.g.
        #LogLevel info ssl:warn

        ErrorLog ${APACHE_LOG_DIR}/error.log
        CustomLog ${APACHE_LOG_DIR}/access.log combined

        # For most configuration files from conf-available/, which are
        # enabled or disabled at a global level, it is possible to
        # include a line for only one particular virtual host. For example the
        # following line enables the CGI configuration for this host only
        # after it has been globally disabled with "a2disconf".
        #Include conf-available/serve-cgi-bin.conf
</VirtualHost>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
```

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ sudo systemctl restart apache2
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ curl -I http://localhost
HTTP/1.1 301 Moved Permanently
Date: Fri, 02 Oct 2026 20:12:49 GMT
Server: Apache/2.4.52 (Ubuntu)
Location: https://vm-team4-dvwa.ironbridge.local/
Content-Type: text/html; charset=iso-8859-1

jm-admin@vm-team1-dvwa:~/A6_evidence/tls$
```

‘sudo nano /etc/apache2/sites-available/000-default.conf’ to edit virtual host HTTP 80 adding:

ServerName vm-team4-dvwa.ironbridge.local

Redirect permanent / https://vm-team4-dvwa.ironbridge.local/

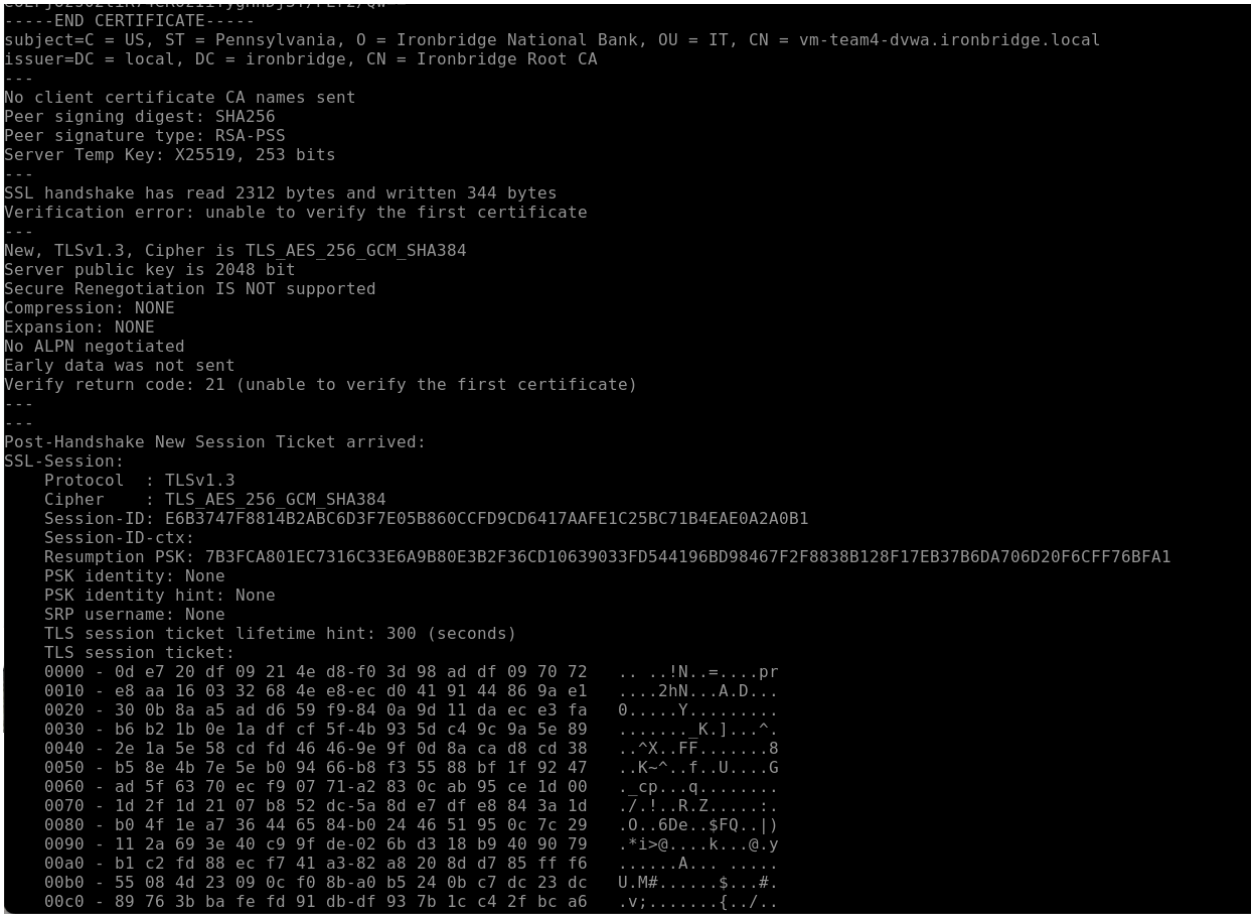
This redirects HTTP to HTTPS

Disable weak protocol versions and weak ciphers

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl s_client -connect 10.10.60.197:443 -tls1
CONNECTED(00000003)
80EB52682E780000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:104:
---
no peer certificate available
---
No client certificate CA names sent
---
SSL handshake has read 0 bytes and written 7 bytes
Verification: OK
---
New, (NONE), Cipher is (NONE)
Secure Renegotiation IS NOT supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl s_client -connect 10.10.60.197:443 -tls1_1
CONNECTED(00000003)
806B5DA63E7D0000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:104:
---
no peer certificate available
---
No client certificate CA names sent
---
SSL handshake has read 0 bytes and written 7 bytes
Verification: OK
---
New, (NONE), Cipher is (NONE)
Secure Renegotiation IS NOT supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---
```

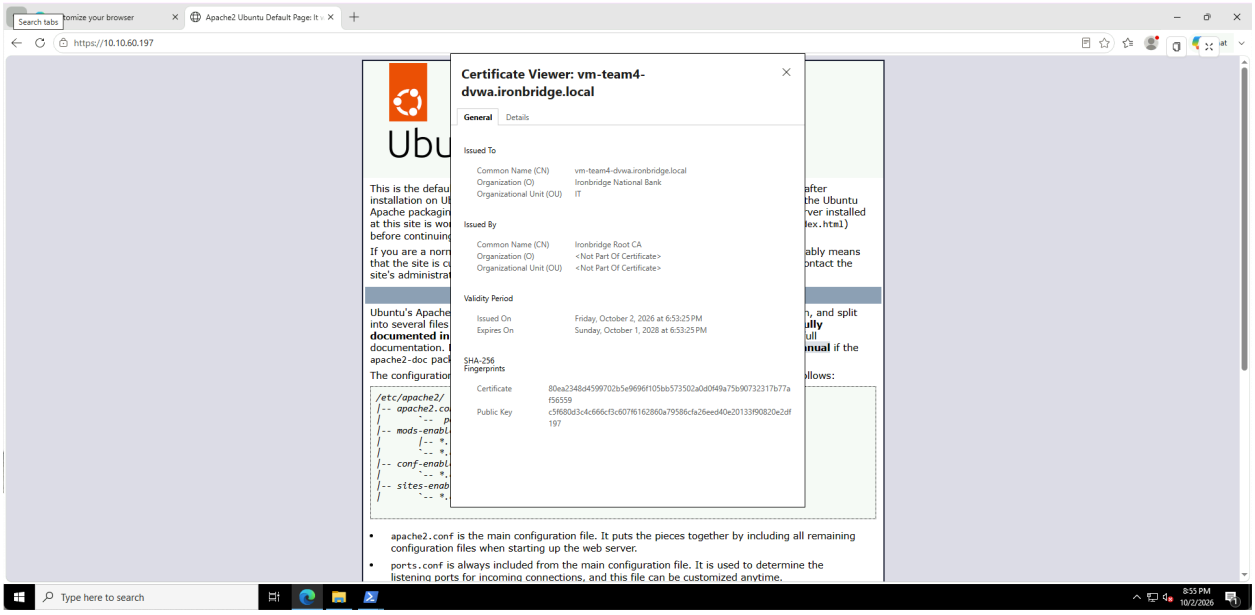
Connecting using TLS 1 correctly fails, proves disabling of weak legacy protocols

```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl s_client \
> -connect 10.10.60.197:443 \
> -servername vm-team4-dvwa.ironbridge.local \
> -tls1_3
CONNECTED(00000003)
depth=0 C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
verify error:num=20:unable to get local issuer certificate
verify return:1
depth=0 C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
verify error:num=21:unable to verify the first certificate
verify return:1
depth=0 C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
verify return:1
---
Certificate chain
 0 s:C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
   i:DC = local, DC = ironbridge, CN = Ironbridge Root CA
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: Oct  2 18:53:25 2026 GMT; NotAfter: Oct  1 18:53:25 2028 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIG2DCCBMCgAwIBAgITSwAAAAN5lM9Ypz9lXAAAAAAAAzANBgkqhkiG9w0BAQsF
ADBQMRUwEwYKCZImiZPyLGQBGRYFbG9jYWwxGjAYBgoJkiaJk/IsZAEZFgppcm9u
YnJpZGdlMRswGQYDVQQDExJJcm9uYnJpZGdlIFJvb3QgQ0EwHhcNMjYxMDAyMTg1
MzI1WhcNMjgxMDAxMTg1MzI1WjB9MQswCQYDVQQGEwJVUzEVMBMGA1UECBMMUGVu
bnN5bHZhbmlhMSEwHwYDVQQKExhJcm9uYnJpZGdlIE5hdGlvbmFsIEJhbmsxCzAJ
BgNVBAsTAktlUMScwJQYDVQQDEx52bS10ZWFtNC1kdndhLmlyb25icmlkZ2UubG9j
YWwwggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCi6pWipSLsrewnKAO5
KixzHwphLJQDsfxUsk5YGiJ1IeMkbguXYmvfJftGMs7ihbgPW4/nyby0TkwdpqgM
bNmwOrKSbbb2HnXzgKqa/dIQiHFjbBFMCUrHLfvy7VCfhfIFSwk5e+E8OWIlEDoY
yWIWqMhSimgYYXJnnBkB+l7HuzKy4aVMAs+E7r/ouF0/fEr9pGsTsQu/Ufujhlzj
KZADGmJvD8qm5cpXbqvchMQjdRTbNs7GhL+Y7pH6dM3Fy1G3HK6qDeKWFcrZpe5M
ivd3DlLBEPmsM1u5HrLftnt+M8JfrnkV9EMOZBFgJSiGpqHkeXjfh7B2xnNjGqub
Io/dAgMBAAGjggJ8MIICeDA+BgNVHREENzA1gh52bS10ZWFtNC1kdndhLmlyb25i
cmlkZ2UubG9jYWyCDXZtLXRlYW00LWR2d2GHBAoKPMUwHQYDVR0OBBYEFM9kyXKb
viU6tb0g0CTtiZMHwVUmMB8GA1UdIwQYMBaAFNgxIcYSDx+w5nyZ/nyrBHy3RbZu
MIHdBgNVHR8EgdUwgdIwgc+ggcygcmGgcZsZGFwOi8vL0NOPUlyb25icmlkZ2Ul
MjBSb290JTIwQ0EsQ049dm0tdGVhbTQtZGMsQ049Q0RQLENOPVB1YmxpYyUyMEtl
eSUyMFNlcnZpY2VzLENOPVNlcnZpY2VzLENOPUNvbmZpZ3VyYXRpb24sREM9aXJv
bmJyaWRnZSxEQz1sb2NhbD9jZXJ0aWZpY2F0ZVJldm9jYXRpb25MaXN0P2Jhc2U/
b2JqZWN0Q2xhc3M9Y1JMRGlzdHJpYnV0aW9uUG9pbnQwgc0GCCsGAQUFBwEBBIHA
MIG9MIG6BggrBgEFBQcwAoaBrWxkYXA6Ly8vQ049SXJvbmJyaWRnZSUyMFJvb3Ql
MjBDQSxDTj1BSUEsQ049UHVibGljJTIwS2V5JTIwU2VydmljZXMsQ049U2Vydmlj
ZXMsQ049Q29uZmlndXJhdGlvbixEQz1pcm9uYnJpZGdlLERDPWxvY2FsP2NBQ2Vy
dGlmaWNhdGU/YmFzZT9vYmplY3RDbGFzczljZXJ0aWZpY2F0aW9uQXV0aG9yaXR5
MCEGCSsGAQQBgjcUAgQUHhIAVwBlAGIAUwBlAHIAdgBlAHIwDgYDVR0PAQH/BAQD
AgWgMBMGA1UdJQQMMAoGCCsGAQUFBwMBMA0GCSqGSIb3DQEBCwUAA4ICAQAl82O1
jSLrfv4V/kgm5Y5yhhPRqbV6flfwwHUCtuTo8UuDWnbe2QTyULceuH7KjesEjteO
```



Connecting using TLS 3 (and TLS 2) succeeds with certificate, protocol and version
This proves established connections through modern TLS versions

Verify the chain of trust in a browser and with an OpenSSL client



Verified the HTTPS certificate from a Windows client that trusted the Ironbridge Root CA
The browser recognized the web server certificate as issued by the internal CA, showing successful certificate-chain validation

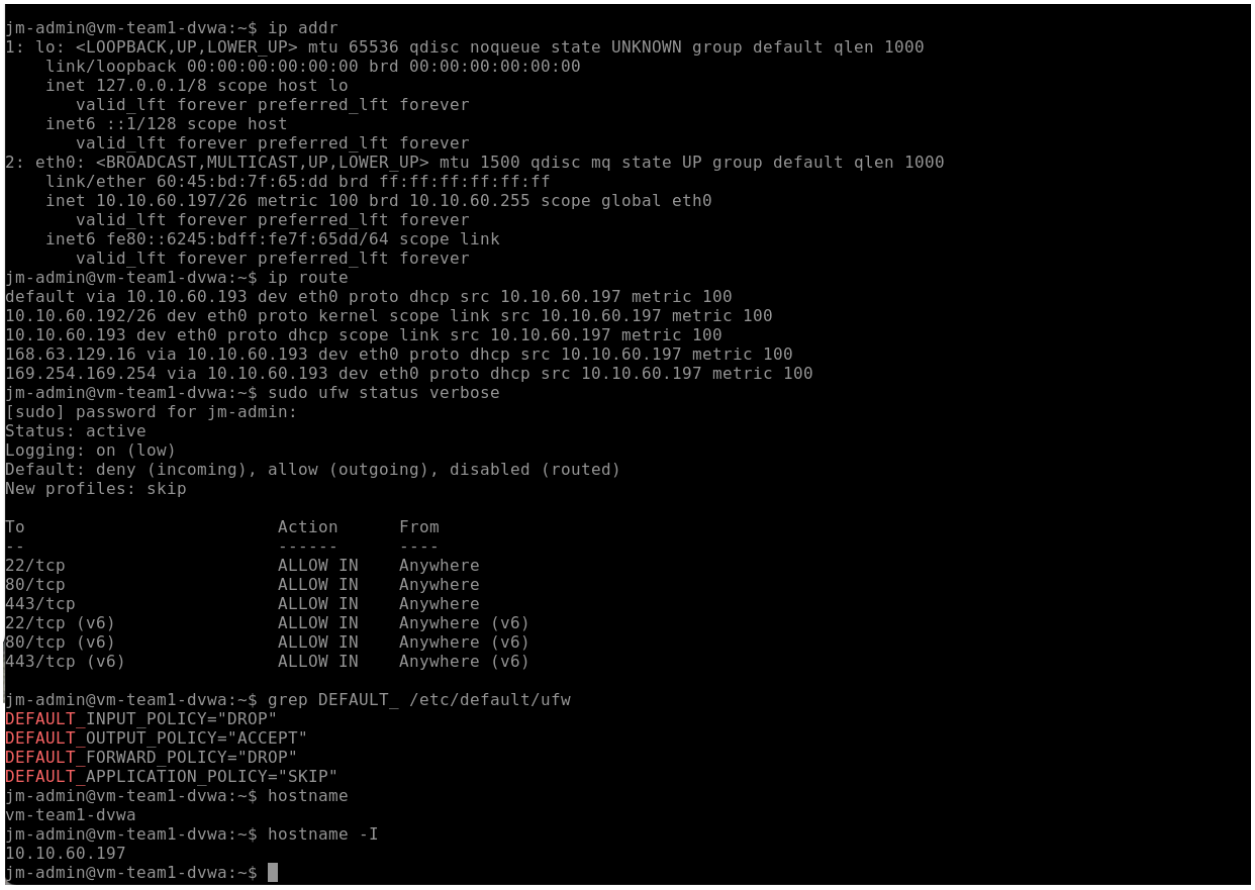
```
jm-admin@vm-team1-dvwa:~/A6_evidence/tls$ openssl s_client \
> -connect 10.10.60.197:443 \
> -servername vm-team4-dvwa.ironbridge.local \
> -CAfile ~/A6_evidence/tls/ironbridge-root-ca.crt \
> -verify_return_error
CONNECTED(00000003)
depth=1 DC = local, DC = ironbridge, CN = Ironbridge Root CA
verify return:1
depth=0 C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
verify return:1
---
Certificate chain
 0 s:C = US, ST = Pennsylvania, O = Ironbridge National Bank, OU = IT, CN = vm-team4-dvwa.ironbridge.local
   i:DC = local, DC = ironbridge, CN = Ironbridge Root CA
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: Oct  2 18:53:25 2026 GMT; NotAfter: Oct  1 18:53:25 2028 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIG2DCCBMCgAwIBAgITSwAAAAN5lM9Ypz9lXAAAAAAAAzANBgkqhkiG9w0BAQsF
ADBQMRUwEwYKCZImiZPyLGQBGRYFbG9jYWwxGjAYBgoJkiaJk/IsZAEZFgppcm9u
YnJpZGdlMRswGQYDVQQDExJJcm9uYnJpZGdlIFJvb3QgQ0EwHhcNMjYxMDAyMTg1
MzI1WhcNMjgxMDAxMTg1MzI1WjB9MQswCQYDVQQGEwJVUzEVMBMGA1UECBMMUGVu
bnN5bHZhbmlhMSEwHwYDVQQKExhJcm9uYnJpZGdlIE5hdGlvbmFsIEJhbmsxCzAJ
BgNVBAsTAklUMScwJQYDVQQDEx52bS10ZWFtNC1kdndhLmlyb25icmlkZ2UubG9j
YWwwggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCi6pWipSLsrewnKAO5
KixzHwphLJQDsfxUsk5YGiJ1IeMkbguXYmvfJftGMs7ihbgPW4/nyby0TkwdpqgM
bNmwOrKSbbb2HnXzgKqa/dIQiHFjbBFMCUrHLfvy7VCfhfIFSwk5e+E8OWIlEDoY
yWIWqMhSimgYYXJnnBkB+l7HuzKy4aVMAs+E7r/ouF0/fEr9pGsTsQu/Ufujhlzj
KZADGmJvD8qm5cpXbqvchMQjdRTbNs7GhL+Y7pH6dM3Fy1G3HK6qDeKWFcrZpe5M
ivd3DlLBEPmsM1u5HrLftnt+M8JfrnkV9EMOZBFgJSiGpqHkeXjfh7B2xnNjGqub
Io/dAgMBAAGjggJ8MIICeDA+BgNVHREENzA1gh52bS10ZWFtNC1kdndhLmlyb25i
cmlkZ2UubG9jYWyCDXZtLXRlYW00LWR2d2GHBAoKPMUwHQYDVR0OBBYEFM9kyXKb
viU6tb0g0CTtiZMHwVUmMB8GA1UdIwQYMBaAFNgxIcYSDx+w5nyZ/nyrBHy3RbZu
MIHdBgNVHR8EgdUwgdIwgc+ggcyggcmGgcZsZGFwOi8vL0NOPUlyb25icmlkZ2Ul
MjBSb290JTIwQ0EsQ049dm0tdGVhbTQtZGMsQ049Q0RQLENOPVB1YmxpYyUyMEtl
eSUyMFNlcnZpY2VzLENOPVNlcnZpY2VzLENOPUNvbmZpZ3VyYXRpb24sREM9aXJv
bmJyaWRnZSxEQz1sb2NhbD9jZXJ0aWZpY2F0ZVJldm9jYXRpb25MaXN0P2Jhc2U/
b2JqZWN0Q2xhc3M9Y1JMRGlzdHJpYnV0aW9uUG9pbnQwgc0GCCsGAQUFBwEBBIHA
MIG9MIG6BggrBgEFBQcwAoaBrWxkYXA6Ly8vQ049SXJvbmJyaWRnZSUyMFJvb3Ql
MjBDQSxDTj1BSUEsQ049UHVibGljJTIwS2V5JTIwU2VydmljZXMsQ049U2Vydmlj
ZXMsQ049Q29uZmlndXJhdGlvbixEQz1pcm9uYnJpZGdlLERDPWxvY2FsP2NBQ2Vy
dGlmaWNhdGU/YmFzZT9vYmplY3RDbGFzcz1jZXJ0aWZpY2F0aW9uQXV0aG9yaXR5
```

```
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: RSA-PSS
Server Temp Key: X25519, 253 bits
---
SSL handshake has read 2312 bytes and written 412 bytes
Verification: OK
---
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Server public key is 2048 bit
Secure Renegotiation IS NOT supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---
```

Openssl used to verify that the Apache web server was presenting the correct certificate and that the certificate could be validated against the Ironbridge Root CA certificate chain along with TLS 1.3 and AES 256

Part A7. Verify Network Segmentation

Confirming connection from Linux machine (jumpbox) to own DC



Verifying Linux firewall with default deny rules and permitted processes from previous hardening steps in A3

```
jm-admin@vm-team1-dvwa:~$ ping -c 4 10.10.60.196
PING 10.10.60.196 (10.10.60.196) 56(84) bytes of data.
64 bytes from 10.10.60.196: icmp_seq=1 ttl=128 time=7.10 ms
64 bytes from 10.10.60.196: icmp_seq=2 ttl=128 time=0.952 ms
64 bytes from 10.10.60.196: icmp_seq=3 ttl=128 time=1.23 ms
64 bytes from 10.10.60.196: icmp_seq=4 ttl=128 time=2.78 ms

--- 10.10.60.196 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 0.952/3.015/7.095/2.456 ms
jm-admin@vm-team1-dvwa:~$ sudo nmap -Pn -p 22,80,443,3389 10.10.60.196
Starting Nmap 7.80 ( https://nmap.org ) at 2026-10-02 18:37 UTC
Nmap scan report for vm-team4-dc.internal.cloudapp.net (10.10.60.196)
Host is up (0.00055s latency).

PORT     STATE    SERVICE
22/tcp   filtered ssh
80/tcp   filtered http
443/tcp  filtered https
3389/tcp filtered ms-wbt-server
MAC Address: 12:34:56:78:9A:BC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.29 seconds
jm-admin@vm-team1-dvwa:~$
```

```
jm-admin@vm-team1-dvwa:~$ sudo nmap -Pn -p 22,80,443,3389 10.10.60.196
[sudo] password for jm-admin:
Starting Nmap 7.80 ( https://nmap.org ) at 2026-10-02 21:54 UTC
Nmap scan report for vm-team4-dc.internal.cloudapp.net (10.10.60.196)
Host is up (0.00048s latency).

PORT     STATE    SERVICE
22/tcp   filtered ssh
80/tcp   filtered http
443/tcp  filtered https
3389/tcp filtered ms-wbt-server
MAC Address: 12:34:56:78:9A:BC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.30 seconds
jm-admin@vm-team1-dvwa:~$
```

Windows DC 10.10.60.196 confirmed is reachable through ping and nmap scan

Confirming host outside subnet is unreachable

```
jm-admin@vm-team1-dvwa:~$ ping -c 4 10.10.60.134
PING 10.10.60.134 (10.10.60.134) 56(84) bytes of data.

--- 10.10.60.134 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3058ms

jm-admin@vm-team1-dvwa:~$
```

Pinging vm-team3-dc 10.10.60.134 is unreachable with 100% packet loss

Azure NSG inbound/outbound rules

Priority	Name	Port	Protocol	Source	Destination	Action
Inbound Security Rules						
100	Allow-Bastion-In	3389,22	TCP	10.10.40.0/26	Any	Allow
110	Allow-Own-Team	Any	Any	10.10.60.192/26	Any	Allow
200	Deny-Other-Teams	Any	Any	VirtualNetwork	Any	Deny
65000	AllowVnetInBound	Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalan...	Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound	Any	Any	Any	Any	Deny
Outbound Security Rules						
65000	AllowVnetOutBound	Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowInternetOutBound	Any	Any	Any	Internet	Allow
65500	DenyAllOutBound	Any	Any	Any	Any	Deny

Network security group (nsg-team 4) inbound/outbound security rules:
Bastion allowed in, your own subnet allowed to itself, all other team subnets denied

Inbound NSG Rules

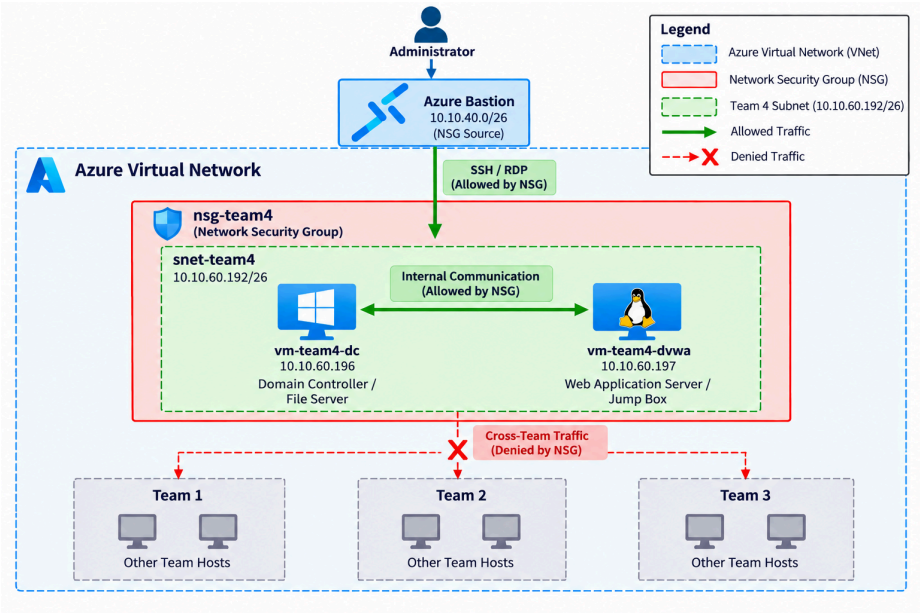
Priority	NSG Rule	Action	Traffic	Business Reasons
100	Allow-Bastion-In	Allow	TCP 22 and 3389 from the Bastion subnet (10.10.40.0/26)	• Secure administrator access • Prevents direct public exposure • Supports SSH and RDP management • Protects banking application infrastructure
110	Allow-Own-Team	Allow	Traffic originating from Team 4 subnet (10.10.60.192/26)	• Enables internal banking services • Allows web server-to-DC communication • Supports authentication and file services • Keeps communication within Team 4
200	Deny-Other-Teams	Deny	Traffic originating from other systems within the virtual network that did not match the Team 4 allow rule	• Enforces network segmentation • Prevents unauthorized cross-team access • Reduces lateral movement risk • Protects banking systems and data

65000	AllowVnetInBound	Allow	Azure Virtual Network traffic	• Supports permitted Azure VNet traffic • Maintains required internal connectivity • Evaluated after Team 4 restrictions • Supports Azure network operations
65001	AllowAzureLoadBalancerInBound	Allow	Azure Load Balancer traffic	• Supports Azure platform services • Allows required health-check traffic • Maintains service availability • Does not expose systems publicly
65500	DenyAllInBound	Deny	All remaining inbound traffic	• Blocks unmatched inbound traffic • Enforces default-deny protection • Reduces attack surface • Protects banking application services

Outbound NSG Rules

Priority	NSG Rule	Action	Traffic	Business Reasons
65000	AllowVnetOutBound	Allow	Traffic destined for the Azure Virtual Network	• Enables required VNet communication • Supports internal banking services • Allows communication with approved resources • Maintains application functionality
65001	AllowInternetOutBound	Allow	Traffic destined for the Internet	• Supports security updates • Allows approved package downloads • Supports system maintenance• Helps keep banking systems patched
65500	DenyAllOutBound	Deny	All remaining outbound traffic	• Blocks unmatched outbound traffic • Provides a final deny control • Limits unauthorized network paths• Reduces unnecessary exposure

Network Diagram



Part A8. Run a Vulnerability Baseline

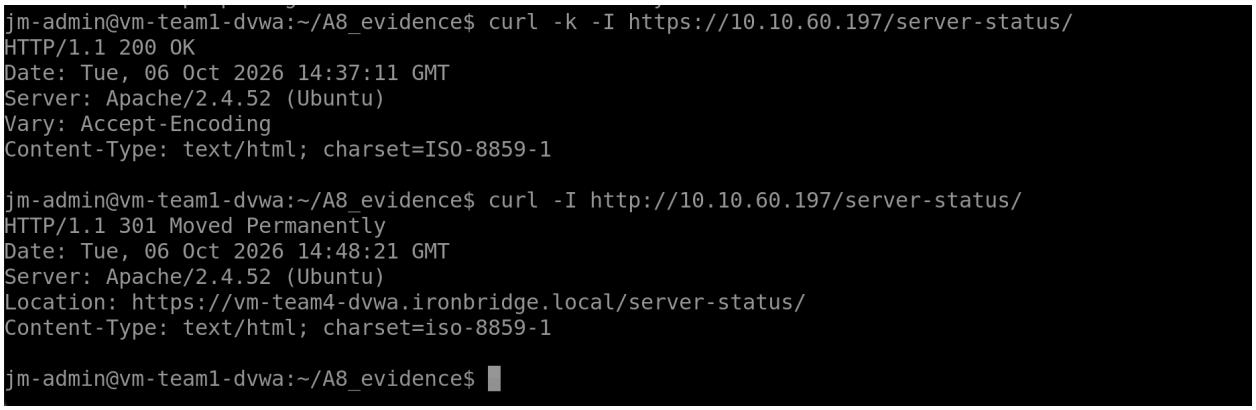
Run a vulnerability scan against both of your hosts using the class scanner or nmap scripts

Linux Environment:

```
jm-admin@vm-team1-dvwa:~/A8_evidence$ cat linux_vuln_scan.txt
# Nmap 7.80 scan initiated Tue Oct  6 13:14:41 2026 as: nmap -Pn -sV --script vuln -oN /home/jm-admin/A8_evidence/linux_vuln_scan.txt 10.10.60.197
Nmap scan report for vm-team1-dvwa.internal.cloudapp.net (10.10.60.197)
Host is up (0.0000060s latency).
Not shown: 997 closed ports
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.17 (Ubuntu Linux; protocol 2.0)
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
| vulners:
|   cpe:/a:openbsd:openssh:8.9p1:
|       PACKETSTORM:179290      10.0    https://vulners.com/packetstorm/PACKETSTORM:179290      *EXPLOIT*
|       1EEC8894-D2F7-547C-827C-915BE866875C    10.0    https://vulners.com/githubexploit/1EEC8894-D2F7-547C-827C-915BE866875C  *EXPLOIT*
|       09B905C6-CD97-54E6-AD97-B0DD1AC4771B    10.0    https://vulners.com/githubexploit/09B905C6-CD97-54E6-AD97-B0DD1AC4771B  *EXPLOIT*
|       PACKETSTORM:173661      9.8     https://vulners.com/packetstorm/PACKETSTORM:173661      *EXPLOIT*
|       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8     https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807  *EXPLOIT*
|       CVE-2023-38408  9.8     https://vulners.com/cve/CVE-2023-38408
|       CVE-2023-28531  9.8     https://vulners.com/cve/CVE-2023-28531
|       B8190CDB-3EB9-5631-9828-8064A1575B23    9.8     https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23  *EXPLOIT*
|       A2B36B85-C737-548F-8C04-9339EDCDBFF5    9.8     https://vulners.com/githubexploit/A2B36B85-C737-548F-8C04-9339EDCDBFF5  *EXPLOIT*
|       8FC9C5AB-3968-5F3C-825E-E8DB5379A623    9.8     https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623  *EXPLOIT*
|       8AD01159-548E-546E-AA87-2DE89F3927EC    9.8     https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC  *EXPLOIT*
|       6192C35D-F78B-5C0A-AB8D-9826A79A5320    9.8     https://vulners.com/githubexploit/6192C35D-F78B-5C0A-AB8D-9826A79A5320  *EXPLOIT*
|       33D623F7-98E0-5F75-80FA-81AA666D1340    9.8     https://vulners.com/githubexploit/33D623F7-98E0-5F75-80FA-81AA666D1340  *EXPLOIT*
|       2227729D-6700-5C8F-8930-1EEAFD4B9FF0    9.8     https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0  *EXPLOIT*
|       0221525F-07F5-5790-912D-F4B9E2D1B587    9.8     https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587  *EXPLOIT*
|       CVE-2026-60002  9.4     https://vulners.com/cve/CVE-2026-60002
|       F8981437-1287-5B69-93F1-657DFB1DCE59    9.3     https://vulners.com/githubexploit/F8981437-1287-5B69-93F1-657DFB1DCE59  *EXPLOIT*
|       CB2926E1-2355-5C82-A42A-D4F72F114F9B    9.3     https://vulners.com/githubexploit/CB2926E1-2355-5C82-A42A-D4F72F114F9B  *EXPLOIT*
|       B6C4923E-8565-5D3E-8E68-8D182C3DAD5C    9.3     https://vulners.com/githubexploit/B6C4923E-8565-5D3E-8E68-8D182C3DAD5C  *EXPLOIT*
|       8DEE261C-33D4-5057-BA46-E4293B705BAE    9.3     https://vulners.com/githubexploit/8DEE261C-33D4-5057-BA46-E4293B705BAE  *EXPLOIT*
|       6FD8F914-B663-533D-8866-23313FD37804    9.3     https://vulners.com/githubexploit/6FD8F914-B663-533D-8866-23313FD37804  *EXPLOIT*
|       PACKETSTORM:190587      8.1     https://vulners.com/packetstorm/PACKETSTORM:190587      *EXPLOIT*
|       FB2E9ED1-43D7-585C-A197-0D6628B20134    8.1     https://vulners.com/githubexploit/FB2E9ED1-43D7-585C-A197-0D6628B20134  *EXPLOIT*
|       FA3992CE-9C4C-5350-8134-177126E0BD3F    8.1     https://vulners.com/githubexploit/FA3992CE-9C4C-5350-8134-177126E0BD3F  *EXPLOIT*
```

```
443/tcp open  ssl/http Apache httpd 2.4.52 ((Ubuntu))
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-enum:
|_  /server-status/: Potentially interesting folder
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_sslv2-drown:
```

Nmap vulnerability scan saved to ‘A8_evidence folder’ revealed many listed vulnerabilities/CVEs to the ports SSH 22, HTTP 80, and HTTPS 443. Upon investigation, none are reachable or exploitable, however the ‘/Server-status/’ folder under 443 is seen as suspicious.



Manual validation confirmed that https://10.10.60.197/server-status/ returned HTTP 200 OK, demonstrating that the endpoint was accessible. The HTTP version returned 301 Moved Permanently, confirming that the previously configured HTTP-to-HTTPS redirect was functioning; however, the redirected HTTPS endpoint is unnecessary and increases attack surface.

Windows Environment Findings:

- RDP uses a self-signed certificate
- WinRM is on HTTP (5985)

Prioritize findings by whether they are actually reachable and exploitable in your environment, not by CVSS number alone

Linux Findings:

Suspicious server-status folder

Windows Findings:

N/A, no significant findings

Remediate what you reasonably can and record an accepted-risk note for anything you cannot

Linux Remediation:

```
jm-admin@vm-team1-dvwa:~$ sudo a2dismod status
[sudo] password for jm-admin:
Module status disabled.
To activate the new configuration, you need to run:
  systemctl restart apache2
jm-admin@vm-team1-dvwa:~$ sudo apache2ctl configtest
Syntax OK
jm-admin@vm-team1-dvwa:~$ sudo systemctl restart apache2
jm-admin@vm-team1-dvwa:~$ sudo systemctl status apache2 --no-pager
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
     Active: active (running) since Wed 2026-10-07 17:52:33 UTC; 34s ago
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 42995 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 42999 (apache2)
      Tasks: 55 (limit: 9500)
     Memory: 6.7M
        CPU: 54ms
     CGroup: /system.slice/apache2.service
             ├─42999 /usr/sbin/apache2 -k start
             ├─43000 /usr/sbin/apache2 -k start
             └─43001 /usr/sbin/apache2 -k start

Oct 07 17:52:33 vm-team1-dvwa systemd[1]: Starting The Apache HTTP Server...
Oct 07 17:52:33 vm-team1-dvwa systemd[1]: Started The Apache HTTP Server.
```

Apache status module was disabled because the server-status functionality was not required for the banking web application's operation. Apache configuration was validated before the service was restarted, and the endpoint was re-tested to confirm remediation.

Windows Remediation:

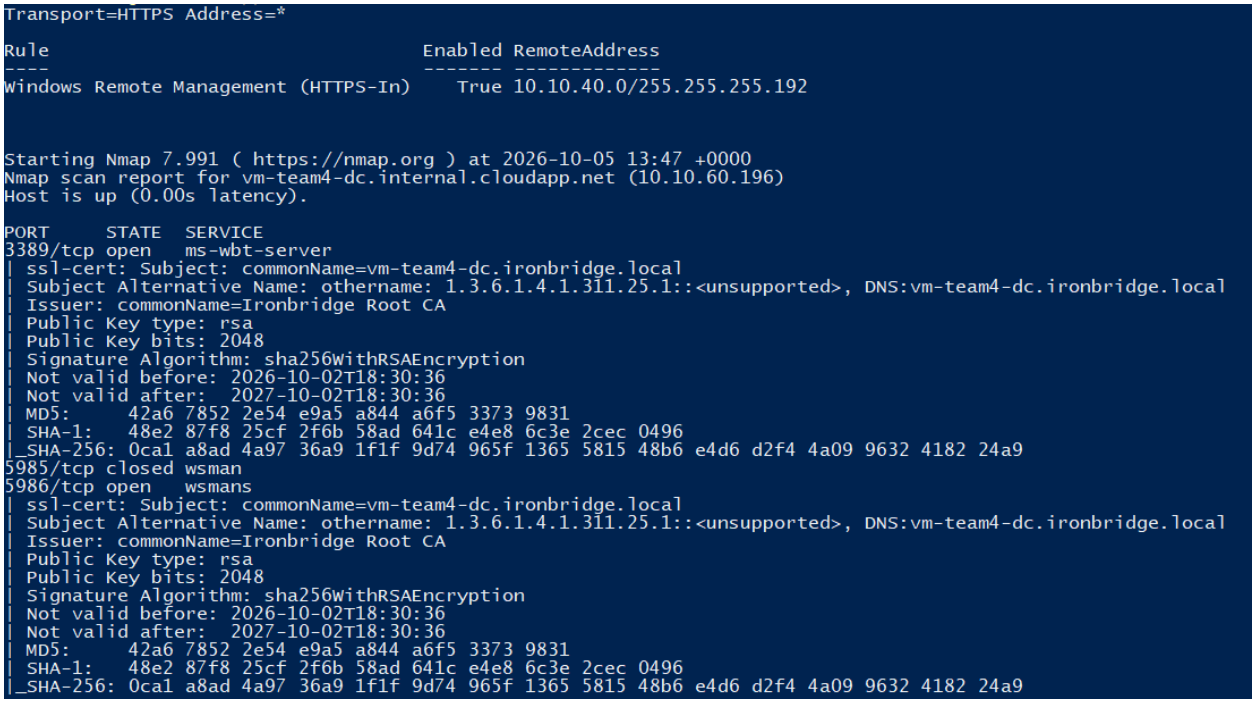
RDP self-signed certificate remediation:

- Now issued by Ironbridge Root CA

```
Subject    : CN=vm-team4-dc.ironbridge.local
Issuer     : CN=Ironbridge Root CA, DC=ironbridge, DC=local
NotBefore  : 10/2/2026 6:30:36 PM
NotAfter   : 10/2/2027 6:30:36 PM
Thumbprint : 48E287F825CF2F6B58AD641CE4E86C3E2CEC0496
```

WinRM on HTTP remediation:

- HTTPS on 5986 only, limited to the Bastion subnet



Re-scan to confirm your fixes closed the finding

Linux Re-scan:

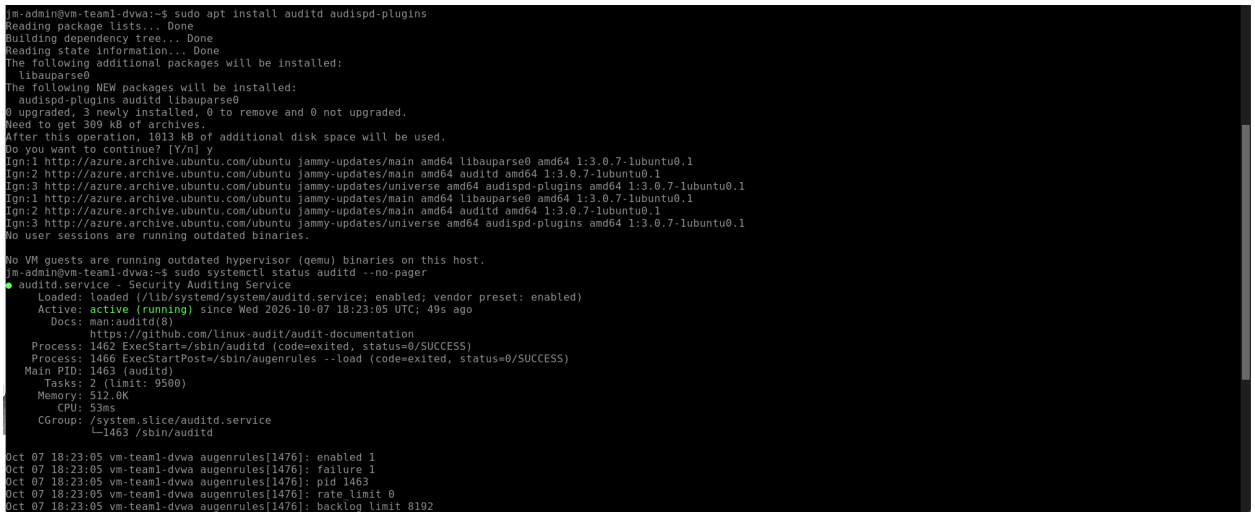
No vulnerabilities found, status module was disabled

Windows Re-scan Summary:

No vulnerabilities found, both the RDP self-signed certificate and WinRM on HTTP are fixed.

Part A12. Endpoint Detection Response

Linux Host:

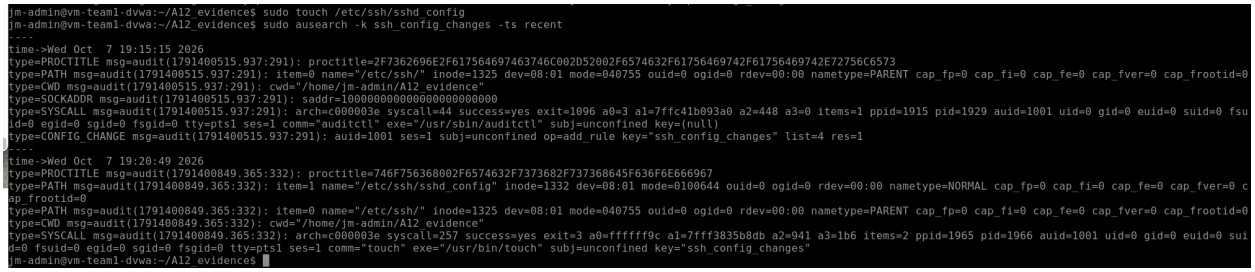


The Linux Auditd service was installed, enabled, and actively running; however, ‘auditctl -l’ returned No rules, demonstrating that no endpoint-specific audit rules had yet been configured.



Persistent audit rules configured in ‘/etc/audit/rules.d/ironbridge-edr.rules’

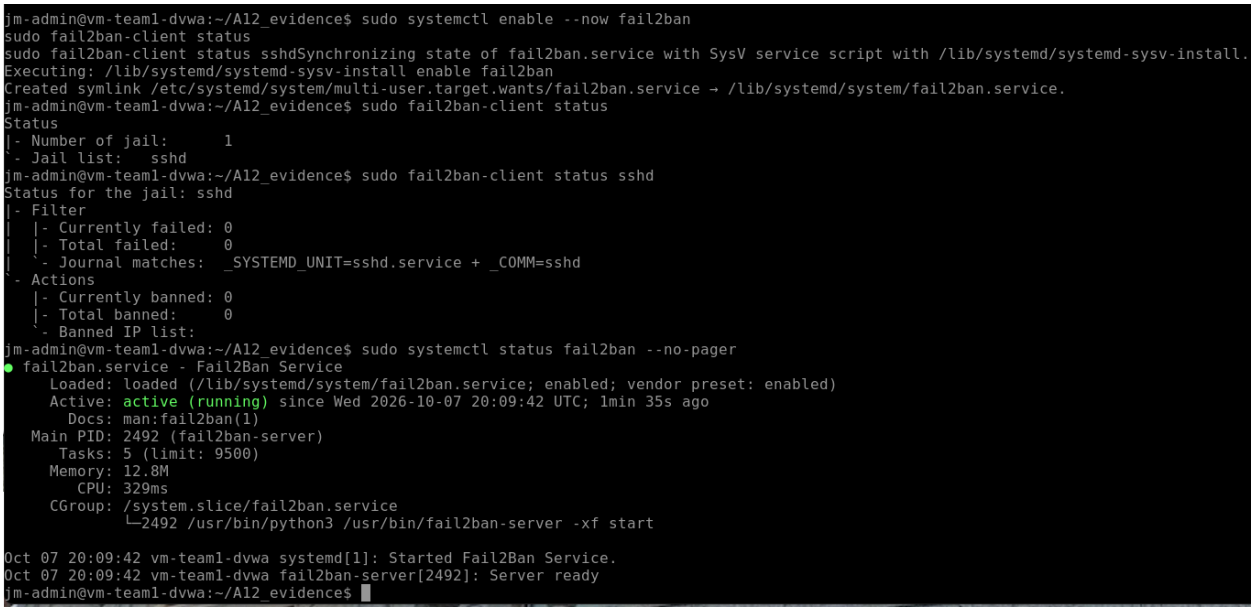
Rule	What it helps detect
/etc/passwd	User account changes
/etc/group	Group/privilege changes
/etc/shadow	Authentication/password changes
/etc/sudoers*	Sudo privilege changes
sshd_config	SSH security configuration changes
/etc/systemd/system/	Service/persistence changes



Testing of a rule: ‘sudo touch /etc/ssh/sshd_config’ correctly detected and displayed in audit log



Fail2ban installed. The sshd jail rules monitor SSH authentication activity and temporarily blocks source IP addresses that exceed the configured threshold of 5 failed attempts within 10 minutes. A matching source is banned for 15 minutes.



Fail2ban enabled. ‘Sudo fail2ban-client status’ correctly shows ‘sshd’ as in the jail list.

Summary:

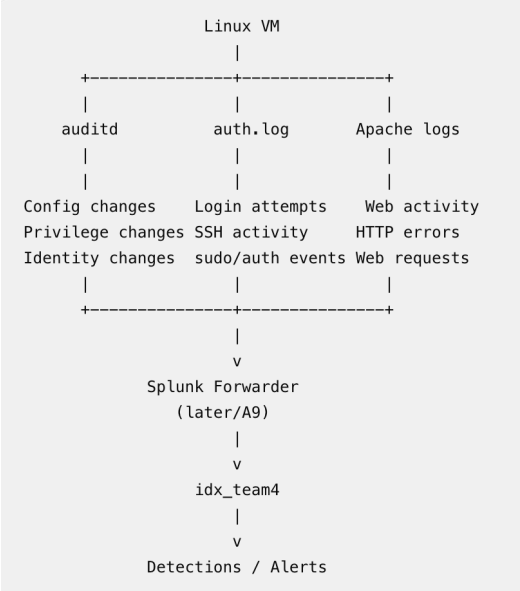
Linux Audit was configured with persistent monitoring rules covering identity files, privilege configuration, SSH configuration, and systemd service configuration. auditctl -l confirms that all seven endpoint-monitoring rules were successfully loaded into the active audit configuration.

Linux endpoint audit monitoring was successfully configured and validated locally. Audit events are being generated for security-sensitive configuration and privilege changes. Centralized

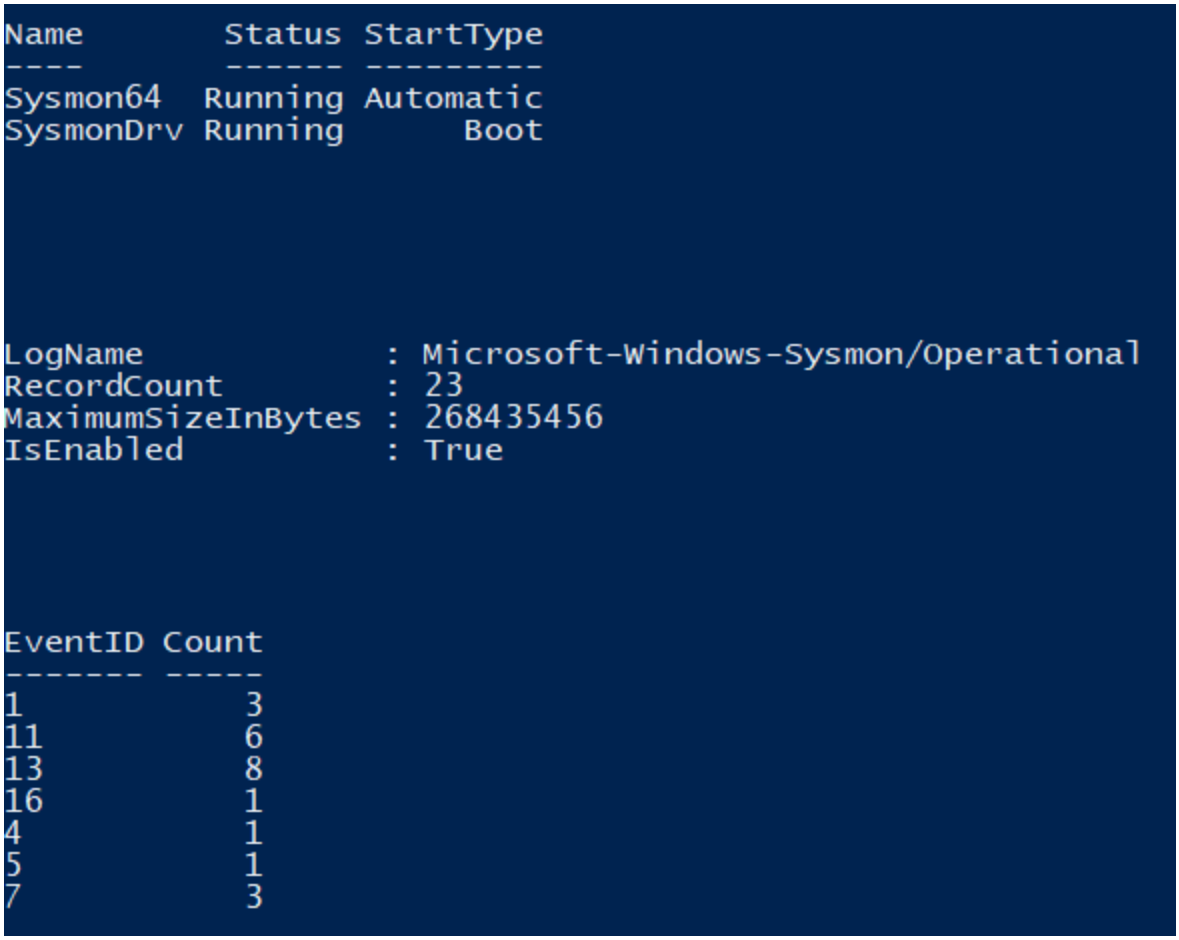
forwarding of this telemetry to idx_team4 will be completed with the Splunk Universal Forwarder as part of the SIEM onboarding process in Part A9.

Additional Linux Endpoint Protection: Fail2ban was implemented to monitor repeated SSH authentication failures and temporarily restrict sources exceeding the configured threshold. This complements key-based SSH authentication and auditd endpoint monitoring by providing an automated response to repeated suspicious authentication activity.

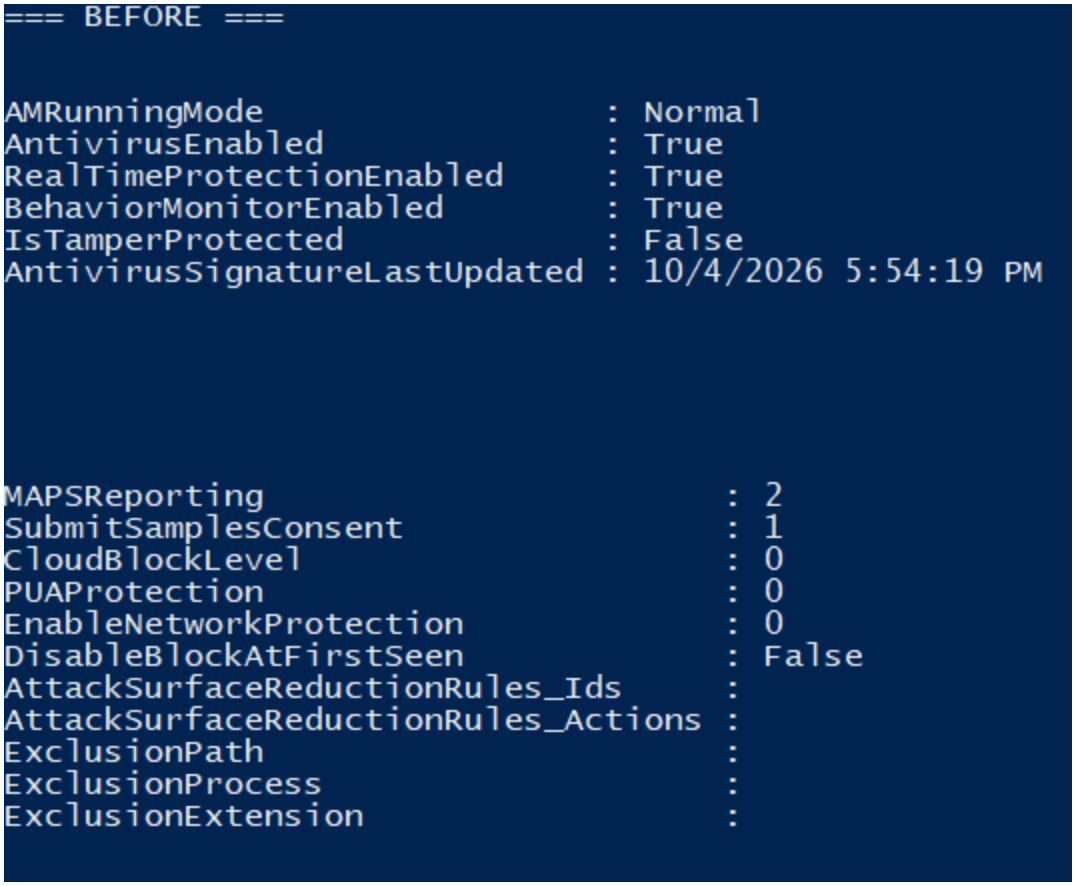
Post EDR Configuration, Telemetry Sources Connecting to Splunk:



Windows Host:
Identified sysmon as EDR software for visibility. Installed and configured sysmon. (Need to connect to Splunk once it is setup).



Hardening Windows Defender
Before:


=== BEFORE ===
AMRunningMode : Normal
AntivirusEnabled : True
RealTimeProtectionEnabled : True
BehaviorMonitorEnabled : True
IsTamperProtected : False
AntivirusSignatureLastUpdated : 10/4/2026 5:54:19 PM
MAPSReporting : 2
SubmitSamplesConsent : 1
CloudBlockLevel : 0
PUAProtection : 0
EnableNetworkProtection : 0
DisableBlockAtFirstSeen : False
AttackSurfaceReductionRules_Ids :
AttackSurfaceReductionRules_Actions :
ExclusionPath :
ExclusionProcess :
ExclusionExtension :

After:

```
=== AFTER ===


AMRunningMode                 : Normal
AntivirusEnabled              : True
RealTimeProtectionEnabled     : True
BehaviorMonitorEnabled        : True
IsTamperProtected             : False
AntivirusSignatureLastUpdated : 10/5/2026 12:10:21 AM




MAPSReporting                     : 2
SubmitSamplesConsent              : 1
CloudBlockLevel                   : 2
CloudExtendedTimeout              : 50
PUAProtection                     : 1
EnableNetworkProtection           : 1
AllowNetworkProtectionOnWinServer : True
DisableBlockAtFirstSeen           : False



Rule                                                                  Action
----                                                                  ------
Block Office applications from creating executable content            Block
Block abuse of exploited vulnerable signed drivers                    Block
Block execution of potentially obfuscated scripts                     Block
Block Office applications from injecting code into other processes    Block
Block Win32 API calls from Office macros                              Block
Block credential stealing from LSASS                                  Block
Block untrusted/unsigned processes that run from USB                  Block
Block executable content from email client and webmail                Block
Use advanced protection against ransomware                            Block
Block process creations from PsExec and WMI commands                  Audit
Block JavaScript/VBScript from launching downloaded executables       Block
Block all Office applications from creating child processes           Block
Block persistence through WMI event subscription                      Block



InitialDetectionTime   ThreatID ActionSuccess
--------------------   -------- -------------
10/5/2026 3:38:21 PM 2147519003          True
```

Configuration changes to Windows Defender:

Category	Setting	Before	After
Signatures	Definition updates	Last scheduled update	Updated manually
Cloud protection	CloudBlockLevel	0 – Default	2 – High
Cloud protection	CloudExtendedTimeout	0 seconds	50 seconds

Unwanted apps	PUA protection	0 – Disabled	1 – Enabled
Network	AllowNetworkProtectionOnWinServer	False	True
Network	Network protection	0 – Disabled	1 – Enabled
Scanning	Removable drive scanning	Disabled	Enabled
ASR	Block credential stealing from LSASS	Not configured	Block
ASR	Block abuse of exploited vulnerable signed drivers	Not configured	Block
ASR	Block execution of potentially obfuscated scripts	Not configured	Block
ASR	Block JavaScript/VBScript from launching downloaded executables	Not configured	Block
ASR	Block persistence through WMI event subscription	Not configured	Block
ASR	Block untrusted/unsigned processes that run from USB	Not configured	Block
ASR	Use advanced protection against ransomware	Not configured	Block
ASR	Block all Office applications from creating child processes	Not configured	Block
ASR	Block Office applications from creating executable content	Not configured	Block
ASR	Block Office applications from injecting code into other processes	Not configured	Block
ASR	Block Win32 API calls from Office macros	Not configured	Block
ASR	Block executable content from email client and webmail	Not configured	Block
ASR	Block process creations from PsExec and WMI commands	Not configured	Audit

Security Gap:

1. Microsoft Defender's Tamper Protection is not enabled (IsTamperProtected = False). Any administrator account could therefore disable Defender, remove its Attack Surface Reduction rules, or add exclusions, which attackers commonly do before deploying malware. Tamper Protection can't be fixed in this lab, because it can only be enabled through Microsoft Defender for Endpoint, Intune, or the Windows Security app. The first two require licensing and portal access the team doesn't have, and the app isn't available on Server Core. The risk is accepted with compensating controls: admin rights are limited to two named accounts plus a break-glass account, remote management is restricted to the Azure Bastion subnet, Sysmon logs the command line of every process, and Defender records all setting changes as Event ID 5007, which can be forwarded to Splunk. The recommended long-term fix is to onboard the server to Microsoft Defender for Endpoint and enable Tamper Protection from the Defender portal.

Powershell Logging
Before:

```
=== BEFORE ===
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging


EnableModuleLogging : 1
PSPath              : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging
PSParentPath        : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell
PSChildName         : ModuleLogging
PSProvider          : Microsoft.PowerShell.Core\Registry



HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging


EnableScriptBlockLogging : 1
PSPath                   : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging
PSParentPath             : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell
PSChildName              : ScriptBlockLogging
PSProvider               : Microsoft.PowerShell.Core\Registry



HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription


EnableTranscripting    : 1
EnableInvocationHeader : 1
OutputDirectory        : C:\PSTranscripts
PSPath                 : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription
PSParentPath           : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell
PSChildName            : Transcription
PSProvider             : Microsoft.PowerShell.Core\Registry



PowerShell log max size: 268435456
```

Validate script blocking:

```
Encoded command: dwBoAG8AYQBtAGkAIAAvAGcAcgBvAHUAcABzAA==


TimeCreated : 10/5/2026 5:28:29 PM
Id          : 4104
Message     : Creating Scriptblock text (1 of 1):
              whoami /groups

              ScriptBlock ID: aea70df7-4251-4c23-9f67-14ec5fe48e1b
              Path:




FullName
--------
C:\PSTranscripts\20261005\PowerShell_transcript.vm-team4-dc.grH2kkAe.20261005172829.txt
```

After:

```
ScriptBlockLogging : 1
ModuleLogging      : 1
ModuleNames        : *
Transcription      : 1
InvocationHeader   : 1
TranscriptFolder   : C:\PSTranscripts
LogMaxSizeMB       : 256
Events4104         : 466
TranscriptFiles    : 2
```

LSA Protection
Before:

```
RunAsPPL before:
Secure Boot: False
```

After:

```
=== AFTER REBOOT ===


TimeCreated : 10/5/2026 5:36:07 PM
Id          : 12
Message     : LSASS.exe was started as a protected process with level: 4.
```

Summary of changes for Powershell & LSA

Setting	**Before**	**After**
PowerShell Script Block Logging (4104)	Off	On
PowerShell Module Logging (4103)	Off	On (all modules)
PowerShell Transcription	Off	On, saved to C:\PSTranscripts (admins only)
PowerShell Operational log size	15 MB	256 MB
LSA Protection (RunAsPPL)	Off	On (LSASS runs as a protected process)

Part B: PCI DSS Compliance Program

Summary

Ironbridge meets 9 of the 12 PCI DSS requirements and partly meets the other 3 (3, 8 and 10). The three gaps are BitLocker that is planned but not yet applied, no MFA, and no central log collection.

Every pointer below gives the Part and page number in the team's *Ironbridge National Bank – Full Documentation* (Infrastructure Documentation PDF, 57 pages), where the screenshot or command output that proves the control can be found.

Requirement mapping

Each evidence pointer is Part, then page, in the Full Documentation PDF. Update the Status column as gaps close.

Requirement	Status	How Ironbridge meets it	Evidence (Full Documentation)
1. Install and maintain network security controls	Met	NSG nsg-team4 allows Bastion in on 22/3389 and the team's own subnet, denies other teams, and denies everything else by default. Host firewalls also default to deny: UFW allows only 22, 80 and 443, and Windows Firewall limits management to Bastion.	A7 NSG rules and network diagram, p. 42–43; A7 segmentation test, p. 40–41; A3 UFW, p. 11–12; A4 Windows Firewall, p. 24
2. Apply secure configurations	Met	Both hosts follow a hardening baseline: root SSH login is off, named admins replace shared default accounts, and unused services and features are removed (snapd, VMware tools, SMBv1, PowerShell v2, Print Spooler, NetBIOS, XPS	A2 baselines, p. 2–10; A3 Linux hardening and before/after table, p. 10–21; A4 roles, features and services, p. 21–22

Requirement	Status	How Ironbridge meets it	Evidence (Full Documentation)
		Viewer, Azure Arc setup).	
3. Protect stored account data	Met (in-plan)	The BankData share is restricted to security groups by least privilege and holds synthetic data only. BitLocker is planned through Azure Disk Encryption (the VM has no vTPM) but not yet applied; Azure storage encryption is the current layer.	A5 access design and NTFS/share permissions, p. 28–30; synthetic data, p. 29; A4 BitLocker plan, p. 25–26
4. Protect data in transit	Met	The web server uses an Ironbridge Root CA certificate, allows only TLS 1.2 and 1.3, disables MD5, 3DES and RC4, and redirects HTTP to HTTPS. RDP and WinRM (HTTPS on 5986) use CA-issued certificates.	A6 CA and certificate, p. 30–34; HTTPS redirect and weak-protocol test, p. 35–37; chain of trust, p. 37–39; A8 RDP and WinRM fix, p. 46–47
5. Protect systems against malware	Met	Both hosts are patched. Defender is hardened (cloud block level High, PUA protection, network protection, 13 ASR rules), Sysmon runs on the DC and Fail2ban on Linux. Tamper Protection being off is an accepted risk with compensating controls.	A3 Linux patching, p. 10; A4 Windows Update, p. 21; A12 Sysmon, p. 50; Defender before/after, p. 51–54; Tamper Protection risk, p. 54–55; Fail2ban, p. 49–50
6. Develop and maintain secure systems	Met	Linux installs security updates automatically. A vulnerability scan was	A3 unattended-upgrades, p. 18–20; web root

Requirement	Status	How Ironbridge meets it	Evidence (Full Documentation)
		run, findings were ranked by real exploitability, and Apache server-status was removed. The web root is root:root 755/644 with no writable files.	permissions, p. 17–18; A8 scan, findings and remediation, p. 44–47
7. Restrict access by business need to know	Met	AD uses bank OUs and AGDLP security groups. BankData gives read/write by role (tellers, branch managers, loan officers, finance) and read-only to compliance, with no Everyone access.	A5 OU structure, p. 27–28; access design, p. 28; NTFS/share permissions and permission model, p. 29–30
8. Identify users and authenticate access	Partial	Each admin has a named account (dy-admin, jm-admin) on both hosts, separate from the break-glass account. SSH accepts keys only. Passwords need 14 characters and accounts lock after 5 failed tries; Fail2ban bans after 5 failed SSH logons. There is no MFA.	A3 named accounts and SSH keys, p. 13–15; A4 password policy, p. 22; admin accounts, p. 23; A5 domain password policy, p. 27; Fail2ban, p. 49
9. Restrict physical access	Met	In the cloud lab, Bastion is the only management path and nothing is exposed directly to the internet. RDP and WinRM accept connections only from the Bastion subnet.	A7 NSG Allow-Bastion-In, p. 42; A4 firewall limits management ports to Bastion, p. 24; A8 WinRM limited to Bastion, p. 46–47

Requirement	Status	How Ironbridge meets it	Evidence (Full Documentation)
10. Log and monitor all access	Partial	Each host logs locally: Windows audit policy, Sysmon, PowerShell script block and module logging with transcription, and Linux auditd rules. Logs are not sent to a central SIEM (Splunk was not implemented) and no retention period is set.	A4 audit policy, p. 23; A12 auditd rules, p. 48–49; Sysmon, p. 50; PowerShell logging, p. 55–56; SIEM pending, p. 50
11. Test security regularly	Met	Both hosts have baseline scans, an nmap vulnerability scan with remediation and a re-scan, and a segmentation test proving other teams' hosts are unreachable.	A2 baseline scans, p. 3–7; A8 vulnerability scan, p. 44–45; re-scan, p. 47; A7 segmentation test, p. 40–41
12. Maintain an information security policy	Met	The incident response plan sets roles, severity levels and playbooks and maps to PCI DSS, and the Full Documentation records every control. Staff complete a security awareness program.	Incident Response Plan; Full Documentation Part A, p. 1–56; Part B, p. 57; security awareness program: [add location]

Gaps and remediation

Closing the three gaps below would bring requirements 3, 8 and 10 to a complete Met.

Requirement	Gap	Remediation
3. Protect stored account data	BitLocker is planned but not applied; only Azure platform encryption protects the disks.	Apply Azure Disk Encryption with Key Vault (XTS-AES 256) as planned on p. 25–26, or redeploy as a Trusted Launch VM with vTPM.

Requirement	Gap	Remediation
8. Identify users and authenticate access	No MFA for administrative access.	Require MFA on the Azure accounts that reach the VMs through Bastion (Azure admin or instructor).
10. Log and monitor all access	No central log collection or retention period.	Forward Windows and Linux logs to a central collector, and keep 12 months of logs with the latest 3 months immediately available (PCI DSS 10.5.1).